

Phase 1 — API Auth & Security Foundations Implementation Plan

For agentic workers: REQUIRED SUB-SKILL: Use superpowers:subagent-driven-development (recommended) or superpowers:executing-plans to implement this plan task-by-task. Steps use checkbox (- []) syntax for tracking.

Goal: Ship API-side UUID-based auth + per-IP fixed-ladder backoff + per-release rotation + L2 client-side encrypted UUID injection + HTTP/3-preferred transport + brotli + constitutional §6.R no-hardcoding mandate.

Architecture: API enforces auth via two new Gin middlewares (backoff → auth) reading config-driven .env values; client embeds AES-GCM-encrypted UUID at build time keyed by HKDF(SHA256(signing-cert) || pepper); Lava-Auth header (name itself config-driven) carries base64(blob) per request; ByteArray zeroize on OkHttp interceptor thread; per-release rotation with active/retired allowlist sets and 426 Upgrade Required for retired.

Tech Stack: Go 1.24 + Gin + quic-go + golang.org/x/crypto/hkdf (API); Kotlin + Hilt + OkHttp + javax.crypto + Compose UI (client); Gradle Kotlin DSL build-time codegen; submodules/ratelimiter (with new pkg/ladder/ primitive contributed upstream).

Spec: docs/superpowers/specs/2026-05-06-phase1-api-auth-design.md (commit 45723b2)

File structure

New files (lava-api-go)

Path	Responsibility
lava-api-go/internal/auth/parse.go	Parse LAVA_AUTH_ACTIVE_CLIENTS / LAVA_AUTH_RETIRED_CLIENTS lines; compute HMAC-SHA256;

Path	Responsibility
	return map[string]string (hash → client name)
lava-api-go/internal/auth/parse_test.go	Unit tests for parse + hash
lava-api-go/internal/auth/middleware.go	AuthMiddleware Gin handler — header → base64 decode → HMAC → active/retired/unknown branch
lava-api-go/internal/auth/middleware_test.go	Unit tests for the three branches
lava-api-go/internal/auth/backoff.go	Thin Lava-side glue over submodules/ratelimiter/pkg/ladder
lava-api-go/internal/auth/backoff_test.go	Unit tests for ladder advancement + reset
lava-api-go/internal/server/brotli.go	Brotli response middleware
lava-api-go/internal/server/brotli_test.go	Unit tests
lava-api-go/internal/server/altsvc.go	Alt-Svc header injection on HTTP/2 responses
lava-api-go/internal/server/altsvc_test.go	Unit tests
lava-api-go/internal/server/protocol_metric.go	Prometheus counter lava_api_request_protocol_total
lava-api-go/internal/server/protocol_metric_test.go	Unit tests
lava-api-go/tests/integration/auth_active_uuid_test.go	§6.G real-stack test
lava-api-go/tests/integration/auth_retired_uuid_test.go	§6.G real-stack test
lava-api-go/tests/integration/auth_unknown_uuid_test.go	§6.G real-stack test
lava-api-go/tests/integration/auth_backoff_ladder_test.go	§6.G real-stack test
lava-api-go/tests/integration/auth_backoff_resets_test.go	§6.G real-stack test
lava-api-go/tests/integration/auth_brotli_response_test.go	§6.G real-stack test
lava-api-go/tests/integration/auth_h3_alt_svc_test.go	§6.G real-stack test
lava-api-go/tests/integration/auth_protocol_metric_test.go	§6.G real-stack test

Path	Responsibility
lava-api-go/tests/contract/auth_field_name_contract_test.go	§6.A contract — .env.example matches code

New files (submodules/ratelimiter — upstream contribution)

Path	Responsibility
submodules/ratelimiter/pkg/ladder/ladder.go	Per-key fixed-ladder backoff state machine
submodules/ratelimiter/pkg/ladder/ladder_test.go	Unit tests + §6.A contract test against ladder schema

New files (Android client)

Path	Responsibility
core/network/impl/src/main/kotlin/lava/network/impl/HKDF.kt	HKDF-SHA256 implementation (no third-party dep)
core/network/impl/src/main/kotlin/lava/network/impl/AesGcm.kt	AES-GCM wrapper around javax.crypto
core/network/impl/src/main/kotlin/lava/network/impl/SigningCertProvider.kt	Reads APK signing cert hash via PackageManager
core/network/impl/src/main/kotlin/lava/network/impl/AuthInterceptor.kt	OkHttp interceptor: decrypt → header → zeroize
core/network/impl/src/main/kotlin/lava/network/di/AuthInterceptorModule.kt	Hilt @IntoSet binding
core/network/impl/src/test/kotlin/lava/network/impl/HKDFTest.kt	RFC 5869 vector tests
core/network/impl/src/test/kotlin/lava/network/impl/AesGcmTest.kt	Round-trip + tamper detection
core/network/impl/src/test/kotlin/lava/network/impl/AuthInterceptorTest.kt	Real-OkHttp interceptor test (with MockWebServer)
core/network/impl/src/test/kotlin/lava/network/impl/SigningCertProviderTest.kt	Mock PackageManager → assert hash
	Gradle task

Path	Responsibility
buildSrc/src/main/kotlin/lava/build/auth/GenerateLavaAuthClass.kt	
buildSrc/src/main/kotlin/lava/build/auth/BuildHKDF.kt	Build-time HKDF (Kotlin std-only)
buildSrc/src/main/kotlin/lava/build/auth/BuildAesGcm.kt	Build-time AES-GCM wrapper
buildSrc/src/test/kotlin/lava/build/auth/GenerateLavaAuthClassTest.kt	Gradle task tests
app/src/main/generated/kotlin/lava/auth/LavaAuth.kt	GENERATED at build time — gitignored
app/src/androidTest/kotlin/lava/app/challenges/C13_AuthHeaderInjectionTest.kt	Compose UI Challenge per §6.G
app/src/androidTest/kotlin/lava/app/challenges/C14_AuthRotationForceUpgradeDialogTest.kt	Compose UI Challenge per §6.G

New files (other)

Path	Responsibility
docs/RELEASE-ROTATION.md	Operator runbook for UUID + pepper rotation
tests/check-constitution/test_clause_6r_present.sh	Hermetic test: §6.R appears in CLAUDE.md
tests/check-constitution/test_clause_6r_inheritance.sh	Hermetic test: §6.R reference in submodules/*/CLAUDE.md
tests/check-constitution/test_no_hardcoded_uuid.sh	Hermetic test: no 36-char UUID outside .env.example
tests/check-constitution/test_no_hardcoded_field_name.sh	Hermetic test: header name not in source
tests/firebase/test_firebase_distribute_pepper_rotation.sh	Hermetic test: pepper-rotation g
tests/firebase/test_firebase_distribute_current_client_name.sh	Hermetic test: LAVA_AUTH_CURRENT_CLIENT validation
.lava-ci-evidence/distribute-changelog/firebase-app-distribution/last-pepper.sha256	Tracks previous pepper for rotation gate

Modified files

Path
CLAUDE.md

Path

AGENTS.md

core/CLAUDE.md

submodules/

{Auth,Cache,Challenges,Concurrency,Config,Containers,Database,Discovery,HTTP3,Mdn SDK}/CLAUDE.md

scripts/check-constitution.sh

scripts/firebase-distribute.sh

scripts/ci.sh

.env.example

lava-api-go/internal/config/config.go

lava-api-go/internal/config/config_test.go

lava-api-go/cmd/lava-api-go/main.go

lava-api-go/internal/server/server.go

lava-api-go/internal/version/version.go

lava-api-go/go.mod

core/tracker/api/.../TrackerDescriptor.kt

core/tracker/impl/...ruTracker descriptor

core/tracker/impl/...rutor descriptor

core/tracker/impl/...internet-archive descriptor

feature/onboarding/.../OnboardingViewModel.kt

feature/menu/.../MenuViewModel.kt

app/src/main/kotlin/.../MainActivity.kt

core/preferences/.../PreferencesKeys

app/build.gradle.kts

core/network/impl/src/main/kotlin/lava/network/di/NetworkModule.kt

Path

core/network/impl/build.gradle.kts

app/.gitignore

CHANGELOG.md

.lava-ci-evidence/distribute-changelog/firebase-app-distribution/1.2.7-1027.md

.lava-ci-evidence/distribute-changelog/container-registry/2.1.0-2100.md

app/proguard-rules.pro

Phase 0: Investigation findings (no code, planning anchor only)

Already resolved during plan-writing — recorded here for executors.

- **§14.1 RateLimiter audit:** No fixed-ladder primitive exists. Phase 3 contributes pkg/ladder/ upstream.
 - **§14.2 TrackerDescriptor:** Lives at core/tracker/api/src/main/kotlin/lava/tracker/api/TrackerDescriptor.kt. Has verified: Boolean for §6.G; we ADD apiSupported: Boolean separately.
 - **§14.3 OkHttp registration:** NetworkModule uses Hilt @Multibinds fun interceptors(): Set<@JvmSuppressWildcards Interceptor> and applies them via apply { interceptors.forEach(::addInterceptor) }. Adding our AuthInterceptor is @IntoSet @Provides. The order is non-deterministic by Hilt; we use a small wrapper that ensures AuthInterceptor runs LAST (closest to the network) by setting it as a network-interceptor instead of an application-interceptor — see Phase 10.
 - **§14.4 Keystore wiring:** Existing pattern uses rootProject.file("\$keystoreRootDir/{debug,release}.keystore") resolved by keystoreLoader. Build-time codegen reads via KeyStore.getInstance("JKS").load(FileInputStream(file), password.toCharArray()) then getCertificate(alias).encoded for DER.
 - **§14.5 check-constitution.sh:** Sequential-check bash script; extending follows existing pattern.
 - **§14.6 firebase-distribute.sh:** §6.P gates in lines 60-100; new gates extend the same if pattern.
-

Phase 1: Constitutional addition — §6.R no-hardcoding mandate

Rationale: Land §6.R FIRST so subsequent phases' commits comply with it from day one. Adding it after the fact would require auditing every preceding commit.

Task 1.1: Add §6.R to root CLAUDE.md

Files:

- Modify: CLAUDE.md — insert §6.R between §6.Q and §6.L



Step 1.1.1: Read current §6.Q location

```
grep -n '##### 6.Q\|##### 6.L' CLAUDE.md
```

Note the line numbers; §6.R goes after §6.Q's closing inheritance paragraph and before §6.L.



Step 1.1.2: Insert §6.R clause text

Insert exactly the following block between the last paragraph of §6.Q and the §6.L heading:

```
##### 6.R — No-Hardcoding Mandate (added 2026-05-06, FOURTEENTH §6.L invocation)
```

```
**Forensic anchor:** 2026-05-06 operator directive during Phase 1 brainstorm: "Pay attention that we MUST NOT hardcode anything ever!" – restating the spirit of §6.J for an entire class of bluffs (literal values that drift silently from their intended source-of-truth).
```

```
**Rule.** No connection address, port, header field name, credential, key, salt, secret, schedule, algorithm parameter, or domain literal shall appear as a string/int constant in tracked source code (`.kt`, `.java`, `.go`, `.gradle`, `.kts`, `.xml`, `.yaml`, `.yml`, `.json`, `.sh`). Every such value MUST come from a config source: `.env` (gitignored), generated config class (build-time codegen reading `.env`), runtime env var, or mounted file.
```

The placeholder file ``.env.example`` (committed) carries dummy values for every variable so a developer cloning the repo knows what to set.

``.scripts/check-constitution.sh`` MUST grep tracked files for forbidden literal patterns:

- Any IPv4 address outside ``.env.example`` and incident docs
- The header name from ``.env.example``'s ``LAVA_AUTH_FIELD_NAME``
- Any 36-char UUID outside ``.env.example``
- Hardcoded ``host:port`` pairs in HTTP/HTTPS URLs

Pre-push rejects on match. Bluff-Audit stamp required on any commit that adds new config-driven values, demonstrating the no-hardcoding contract test fails when a literal is reintroduced.

****Exemptions**** (test fixtures, incident docs, design specs):

- ``.env.example`` – by definition carries placeholders
- ``.lava-ci-evidence/sixth-law-incidents/*.json`` – forensic anchors quoting historical literals
- ``.docs/superpowers/specs/*.md`` – design docs may show example values for clarity (placeholders preferred but examples permitted)
- ``*_test.go``, ``*Test.kt`` – test fixtures may use synthetic literals, MUST NOT use real production values

****Inheritance:**** applies recursively to every submodule and every new artifact. Submodule constitutions MAY add stricter rules but MUST NOT relax this clause.



Step 1.1.3: Verify the clause renders correctly

```
grep -n '##### 6.R' CLAUDE.md
```

Expected: one match.



Step 1.1.4: Commit

```
git add CLAUDE.md
git commit -m "$(cat <<'EOF'
constitution(6.R): add No-Hardcoding Mandate (FOURTEENTH §6.L
invocation)
```

Operator directive 2026-05-06 during Phase 1 brainstorm: "Pay attention that we MUST NOT hardcode anything ever!" Codifies the rule with grep enforcement via scripts/check-constitution.sh (extension lands in Phase 1 Task 1.5).

Co-Authored-By: Claude Opus 4.7 (1M context)
<noreply@anthropic.com>

```
EOF
)"
```


Task 1.2: Mirror §6.R into AGENTS.md

Files: Modify AGENTS.md.



Step 1.2.1: Insert the same §6.R block into AGENTS.md

Locate the corresponding "Constitutional clauses" section in AGENTS.md (mirror the position used in CLAUDE.md). Insert the same §6.R block.



Step 1.2.2: Commit

```
git add AGENTS.md
git commit -m "constitution(6.R): mirror No-Hardcoding Mandate to
AGENTS.md"
```

Co-Authored-By: Claude Opus 4.7 (1M context)
<noreply@anthropic.com>

Task 1.3: Propagate §6.R to all 16 submodules' CLAUDE.md per §6.F inheritance

Files: Modify each submodules/<Name>/CLAUDE.md.



Step 1.3.1: Identify the 16 submodules

```
ls -ld submodules/*/CLAUDE.md
```

Expected: 16 paths (Auth, Cache, Challenges, Concurrency, Config, Containers, Database, Discovery, HTTP3, Mdns, Middleware, Observability, RateLimiter, Recovery, Security, Tracker-SDK).



Step 1.3.2: Append §6.R reference paragraph to each

For each submodule's CLAUDE.md, append (or insert in the constitutional-clauses section if one exists):

```
## §6.R – No-Hardcoding Mandate (inherited 2026-05-06, per §6.F)
```

```
See root `/CLAUDE.md` §6.R. No connection address, port, header
field name, credential, key, salt, secret, schedule,
algorithm parameter, or domain literal in tracked source
code. Every such value MUST come from
`.env` (gitignored), generated config, runtime env var, or
mounted file. Submodule MAY add stricter rules but MUST
NOT relax.
```



Step 1.3.3: Commit (one commit covering all 16)

```
git add submodules/*/CLAUDE.md
git commit -m "constitution(6.R): propagate to 16 vasic-digital
submodules per §6.F"
```

Co-Authored-By: Claude Opus 4.7 (1M context)
<noreply@anthropic.com>"

Task 1.4: Add memory-hygiene clause to core/CLAUDE.md

Files: Modify core/CLAUDE.md.



Step 1.4.1: Append clause

Append to core/CLAUDE.md:

```
## Auth UUID memory hygiene (added 2026-05-06, Phase 1)
```

The decrypted UUID inside the Lava client MUST be held only as ``ByteArray``, never as ``String``. The decrypt-use-zeroize lifetime is bounded by a single `OkHttp` ``Interceptor.intercept()`` call; the ``ByteArray`` is ``fill(0)``d in a ``finally`` block before the function returns. The Base64-encoded header VALUE is a ``String`` (immutable) but never logged, never persisted, never assigned to a class field, and leaves Lava code as soon as `OkHttp` consumes it. Adding logging that includes the header value is a constitutional violation; pre-push grep enforces.

The ``core/network/impl/AuthInterceptor`` is the ONLY allowed consumer of ``LavaAuth.BLOB``; reflective access from elsewhere is also a violation.



Step 1.4.2: Commit

```
git add core/CLAUDE.md
git commit -m "constitution(core): add Auth UUID memory hygiene
clause"
```

Co-Authored-By: Claude Opus 4.7 (1M context)
<noreply@anthropic.com>"

Task 1.5: Extend scripts/check-constitution.sh for §6.R enforcement

Files:

- Modify: scripts/check-constitution.sh



Step 1.5.1: Read current structure

```
sed -n '1,50p' scripts/check-constitution.sh
```



Step 1.5.2: Append §6.R enforcement block

Append the following before the script's final echo summary (the section starting with the existing summary line; identify by `grep -n 'submodules/tracker_sdk/CLAUDE.md present' scripts/check-constitution.sh`):

```
# -----
# 6.R – No-Hardcoding Mandate enforcement
# -----

# 6.R clause must appear in root CLAUDE.md
if ! grep -qF '##### 6.R – No-Hardcoding Mandate' CLAUDE.md; then
    echo "MISSING constitutional clause: 6.R – No-Hardcoding
        Mandate" >&2
    echo " → Add to CLAUDE.md per Phase 1 Task 1.1." >&2
    exit 1
fi

# 6.R must appear in every submodules/*/CLAUDE.md (per §6.F
# inheritance)
for sub in submodules/*/CLAUDE.md; do
    if ! grep -qF '6.R – No-Hardcoding Mandate' "$sub"; then
        echo "MISSING 6.R inheritance reference: $sub" >&2
        echo
        " → Append the §6.R reference paragraph per Phase 1 Task
        1.3." >&2
        exit 1
    fi
done

# 6.R: no 36-char UUIDs in tracked source outside .env.example +
# sixth-law incidents + design specs + tests
uuid_violations=$(git ls-files \
| grep -vE '^\.env\.example$|^\.lava-ci-evidence/sixth-law-
incidents/|^docs/superpowers/specs/|_test\.go$|Test\.kt$'
\
| xargs grep -lE '\b[0-9a-fA-F]{8}-[0-9a-fA-F]{4}-[0-9a-fA-F]{4}-[0-9a-fA-F]{4}-[0-9a-fA-F]{12}\b' 2>/dev/null \
```

```

    || true)
if [[ -n "$uuid_violations" ]]; then
    echo "6.R VIOLATION: hardcoded UUIDs in tracked source:" >&2
    echo "$uuid_violations" >&2
    echo " → Move to .env (gitignored); read via config layer." >&2
    exit 1
fi

# 6.R: no IPv4 literals outside .env.example, incidents, specs,
#       tests
ipv4_violations=$(git ls-files \
| grep -vE '^\.env\.example$|^\.lava-ci-evidence/|^docs/|
_test\.go$|Test\.kt$|\.md$|\.yml$|\.yaml$' \
| xargs grep -lE '\b([0-9]{1,3}\.){3}[0-9]{1,3}\b' 2>/dev/
null \
| grep -vE '^scripts/.*\sh$' \
|| true)
if [[ -n "$ipv4_violations" ]]; then
    echo "6.R VIOLATION: hardcoded IPv4 in tracked source:" >&2
    echo "$ipv4_violations" >&2
    echo " → Move to .env (gitignored); read via config layer." >&2
    exit 1
fi

```



Step 1.5.3: Run the checker; verify it passes (no violations yet)

```

bash scripts/check-constitution.sh
echo "Exit: $?"

```

Expected exit 0 + the existing summary line.



Step 1.5.4: Falsifiability rehearsal — introduce a hardcoded UUID, verify rejection

```

# Add a synthetic UUID violation
echo 'val accidentallyHardcoded =
    "12345678-1234-1234-1234-123456789012"' \
> /tmp/violation.kt
mv /tmp/violation.kt core/network/impl/src/main/kotlin/lava/
network/impl/Violation.kt
git add core/network/impl/src/main/kotlin/lava/network/impl/
Violation.kt
bash scripts/check-constitution.sh
# Expected: exit 1 with "6.R VIOLATION: hardcoded UUIDs in tracked
#       source"
RC=$?
echo "Exit: $RC (expected: 1)"

# Revert the violation

```

```
git rm -f core/network/impl/src/main/kotlin/lava/network/impl/
Violation.kt
bash scripts/check-constitution.sh
# Expected: exit 0
echo "Exit: $? (expected: 0)"
```

Record the failure message text for the Bluff-Audit stamp.



Step 1.5.5: Commit with Bluff-Audit stamp

```
git add scripts/check-constitution.sh
git commit -m "$(cat <<'EOF'
ci(check-constitution): enforce §6.R No-Hardcoding (UUID + IPv4
patterns)"
```

Extends scripts/check-constitution.sh with three §6.R checks:

- §6.R clause present in CLAUDE.md
- §6.R inheritance reference in every submodules/*/CLAUDE.md
- No 36-char UUIDs in tracked source (excluding .env.example, sixth-law incidents, design specs, *_test.go, *Test.kt)
- No IPv4 literals in tracked source (same exclusions)

Bluff-Audit: §6.R UUID enforcement (scripts/check-constitution.sh)

Mutation: added a literal UUID to a Kotlin source file

Observed-Failure: "6.R VIOLATION: hardcoded UUIDs in tracked source:"

followed by the violating file path

Reverted: yes – committed checker is unmodified except for new gates

Co-Authored-By: Claude Opus 4.7 (1M context)
<noreply@anthropic.com>

```
EOF
)"
```

Task 1.6: Hermetic test suite for §6.R

Files:

- Create: tests/check-constitution/test_clause_6r_present.sh
- Create: tests/check-constitution/test_clause_6r_inheritance.sh
- Create: tests/check-constitution/test_no_hardcoded_uuid.sh
- Modify: scripts/ci.sh — invoke the new tests



Step 1.6.1: Write test_clause_6r_present.sh

```
cat > tests/check-constitution/test_clause_6r_present.sh <<'EOF'
#!/usr/bin/env bash
# Asserts §6.R clause is present in root CLAUDE.md.
set -euo pipefail
```

```

cd "$(dirname "$0")/../../.."
if grep -qF '##### 6.R – No-Hardcoding Mandate' CLAUDE.md; then
    echo "PASS test_clause_6r_present"
    exit 0
fi
echo "FAIL test_clause_6r_present: $6.R missing from CLAUDE.md"
>&2
exit 1
EOF
chmod +x tests/check-constitution/test_clause_6r_present.sh

```



Step 1.6.2: Write test_clause_6r_inheritance.sh

```

cat > tests/check-constitution/test_clause_6r_inheritance.sh <<'EOF'
#!/usr/bin/env bash
# Asserts $6.R inheritance reference appears in every submodules/
# */CLAUDE.md.
set -euo pipefail
cd "$(dirname "$0")/../../.."
missing=()
for sub in submodules/*/CLAUDE.md; do
    if ! grep -qF '6.R – No-Hardcoding Mandate' "$sub"; then
        missing+=("$sub")
    fi
done
if [[ ${#missing[@]} -eq 0 ]]; then
    echo "PASS test_clause_6r_inheritance"
    exit 0
fi
echo "FAIL test_clause_6r_inheritance: missing in:" >&2
printf '  %s\n' "${missing[@]}" >&2
exit 1
EOF
chmod +x tests/check-constitution/test_clause_6r_inheritance.sh

```



Step 1.6.3: Write test_no_hardcoded_uuid.sh

```

cat > tests/check-constitution/test_no_hardcoded_uuid.sh <<'EOF'
#!/usr/bin/env bash
# Asserts no 36-char UUIDs in tracked source (delegates to check-
# constitution.sh
# for the canonical regex set).
set -euo pipefail
cd "$(dirname "$0")/../../.."
if bash scripts/check-constitution.sh > /tmp/checker.out 2>&1;
then
    echo "PASS test_no_hardcoded_uuid"
    exit 0
fi
if grep -q '6.R VIOLATION: hardcoded UUIDs' /tmp/checker.out; then

```

```

    echo "FAIL test_no_hardcoded_uuid:" >&2
    cat /tmp/checker.out >&2
    exit 1
fi
echo "PASS test_no_hardcoded_uuid (checker failed for unrelated
    reason; recheck independently)"
exit 0
EOF
chmod +x tests/check-constitution/test_no_hardcoded_uuid.sh

```



Step 1.6.4: Wire into scripts/ci.sh

In `scripts/ci.sh`, locate the existing `check-constitution` test invocation, add three new lines next to it:

```

bash tests/check-constitution/test_clause_6r_present.sh
bash tests/check-constitution/test_clause_6r_inheritance.sh
bash tests/check-constitution/test_no_hardcoded_uuid.sh

```



Step 1.6.5: Run all three tests; assert green

```

bash tests/check-constitution/test_clause_6r_present.sh
bash tests/check-constitution/test_clause_6r_inheritance.sh
bash tests/check-constitution/test_no_hardcoded_uuid.sh

```



Step 1.6.6: Falsifiability rehearsal

For each test:

1. `test_clause_6r_present.sh`: temporarily delete the ##### 6.R heading from `CLAUDE.md` → run test → confirm fail → restore via `git checkout CLAUDE.md`
2. `test_clause_6r_inheritance.sh`: temporarily delete the §6.R paragraph from one submodules/*/CLAUDE.md → run test → confirm fail → restore
3. `test_no_hardcoded_uuid.sh`: temporarily add a UUID literal to a .kt file → run test → confirm fail → revert

Record the failure messages for the Bluff-Audit stamp.



Step 1.6.7: Commit with three Bluff-Audit stamps

```

git add tests/check-constitution/test_clause_6r_*.sh \
    tests/check-constitution/test_no_hardcoded_uuid.sh \
    scripts/ci.sh
git commit -m "$(cat <<'EOF'
test(check-constitution): hermetic suite for §6.R enforcement

```

Adds three pre-push-hooked hermetic bash tests for \$6.R:

- test_clause_6r_present.sh: asserts \$6.R header in CLAUDE.md
- test_clause_6r_inheritance.sh: asserts \$6.R reference in every submodules/*/CLAUDE.md (16 submodules)
- test_no_hardcoded_uuid.sh: asserts no 36-char UUIDs in tracked source outside the documented exemption set

Bluff-Audit: test_clause_6r_present.sh
Mutation: removed `##### 6.R` heading from CLAUDE.md
Observed-Failure: "FAIL test_clause_6r_present: \$6.R missing from CLAUDE.md"
Reverted: yes

Bluff-Audit: test_clause_6r_inheritance.sh
Mutation: removed \$6.R paragraph from submodules/auth/CLAUDE.md
Observed-Failure: "FAIL test_clause_6r_inheritance: missing in: submodules/auth/CLAUDE.md"
Reverted: yes

Bluff-Audit: test_no_hardcoded_uuid.sh
Mutation: added UUID literal to core/network/impl/src/main/kotlin/.../Violation.kt
Observed-Failure: "6.R VIOLATION: hardcoded UUIDs in tracked source:"
followed by the violating file path
Reverted: yes

Co-Authored-By: Claude Opus 4.7 (1M context)
<noreply@anthropic.com>

EOF
)"

Phase 2: .env.example + lava-api-go config layer extension

Task 2.1: Extend .env.example with new placeholders

Files: Modify .env.example.



Step 2.1.1: Append the new variables

Append (organize as commented sections):

```
# === Phase 1 (2026-05-06): API auth + transport ===  
  
# Auth field identifier (read by both API + Android build)  
LAVA_AUTH_FIELD_NAME=Lava-Auth
```



```

# Allowlist + rotation
LAVA_AUTH_CURRENT_CLIENT_NAME=android-1.2.7-1027
LAVA_AUTH_ACTIVE_CLIENTS=android-1.2.7-1027:00000000-0000-0000-0000-000000000000
LAVA_AUTH_RETIRED_CLIENTS=

# API-only
LAVA_AUTH_HMAC_SECRET=cGxhY2Vob2xkZXItcmVwbGFjZS1tZS1pb1lbnYtZmlsZQ==
LAVA_AUTH_BACKOFF_STEPS=2s,5s,10s,30s,1m,1h
LAVA_AUTH_TRUSTED_PROXIES=
LAVA_AUTH_MIN_SUPPORTED_VERSION_NAME=1.2.6
LAVA_AUTH_MIN_SUPPORTED_VERSION_CODE=1026

# Android-build-only
LAVA_AUTH_OBFUSCATION_PEPPER=cGxhY2Vob2xkZXItcmVwbGFjZS1tZS1pb1lbnYtZmlsZQ==

# Transport (API runtime)
LAVA_API_HTTP3_ENABLED=true
LAVA_API_BROTLI_QUALITY=4
LAVA_API_BROTLI_RESPONSE_ENABLED=true
LAVA_API_BROTLI_REQUEST_DECODE_ENABLED=false
LAVA_API_PROTOCOL_METRIC_ENABLED=true

```



Step 2.1.2: Commit

```

git add .env.example
git commit -m
    "config(.env.example): Phase 1 placeholders for auth +
    transport

```

Co-Authored-By: Claude Opus 4.7 (1M context)
 <noreply@anthropic.com>"

Task 2.2: Extend lava-api-go/internal/config/config.go

Files:

- Modify: lava-api-go/internal/config/config.go



Step 2.2.1: Add new struct fields

In Config struct, add after RutrackerBaseUrl:

```

// === Phase 1: Auth ===
AuthFieldName      string
AuthHMACSecret     []byte           // base64-decoded
AuthActiveClients  map[string]string // hash → client
                    name
AuthRetiredClients map[string]string
AuthBackoffSteps   []time.Duration

```

```

AuthTrustedProxies
    []string          // CIDR list, empty = direct
AuthMinSupportedVersionName string
AuthMinSupportedVersionCode int

// === Phase 1: Transport ===
HTTP3Enabled          bool
BrotliQuality          int
BrotliResponseEnabled bool
BrotliRequestDecodeEnabled bool
ProtocolMetricEnabled  bool

```



Step 2.2.2: Add Load() field reads

In Load(), after the RutrackerBaseURL line, add:

```

cfg.AuthFieldName = os.Getenv("LAVA_AUTH_FIELD_NAME")
if cfg.AuthFieldName == "" {
    return nil, errors.New("config: LAVA_AUTH_FIELD_NAME is
        required")
}

secretB64 := os.Getenv("LAVA_AUTH_HMAC_SECRET")
if secretB64 == "" {
    return nil, errors.New("config: LAVA_AUTH_HMAC_SECRET is
        required")
}
secret, err := base64.StdEncoding.DecodeString(secretB64)
if err != nil {
    return nil, fmt.Errorf("config: LAVA_AUTH_HMAC_SECRET base64
        decode: %w", err)
}
if len(secret) < 16 {
    return nil, fmt.Errorf("config: LAVA_AUTH_HMAC_SECRET must be
        at least 16 bytes (got %d)", len(secret))
}
cfg.AuthHMACSecret = secret

cfg.AuthActiveClients, err =
    parseClientsList(os.Getenv("LAVA_AUTH_ACTIVE_CLIENTS"),
        secret)
if err != nil {
    return nil, fmt.Errorf("config: LAVA_AUTH_ACTIVE_CLIENTS:
        %w", err)
}
cfg.AuthRetiredClients, err =
    parseClientsList(os.Getenv("LAVA_AUTH_RETIRED_CLIENTS"),
        secret)
if err != nil {
    return nil, fmt.Errorf("config: LAVA_AUTH_RETIRED_CLIENTS:
        %w", err)
}

```

```

stepsStr := envDefault("LAVA_AUTH_BACKOFF_STEPS",
    "2s,5s,10s,30s,1m,1h")
cfg.AuthBackoffSteps, err = parseBackoffSteps(stepsStr)
if err != nil {
    return nil, fmt.Errorf("config: LAVA_AUTH_BACKOFF_STEPS: %w",
        err)
}

cfg.AuthTrustedProxies =
    parseCSV(os.Getenv("LAVA_AUTH_TRUSTED_PROXIES"))
cfg.AuthMinSupportedVersionName =
    os.Getenv("LAVA_AUTH_MIN_SUPPORTED_VERSION_NAME")
cfg.AuthMinSupportedVersionCode =
    envInt("LAVA_AUTH_MIN_SUPPORTED_VERSION_CODE", 0)

cfg.HTTP3Enabled = envBool("LAVA_API_HTTP3_ENABLED", true)
cfg.BrotliQuality = envInt("LAVA_API_BROTLI_QUALITY", 4)
cfg.BrotliResponseEnabled =
    envBool("LAVA_API_BROTLI_RESPONSE_ENABLED", true)
cfg.BrotliRequestDecodeEnabled =
    envBool("LAVA_API_BROTLI_REQUEST_DECODE_ENABLED", false)
cfg.ProtocolMetricEnabled =
    envBool("LAVA_API_PROTOCOL_METRIC_ENABLED", true)

```



Step 2.2.3: Add helper functions at file bottom

```

// parseClientsList parses a CSV of "name:uuid" entries and
// returns a
// map keyed by HMAC-SHA256(uuid, secret) hex-encoded, valued by
// name.
// The plaintext UUID byte slice is zeroized after hashing.
func parseClientsList(csv string, secret []byte)
    (map[string]string, error) {
    out := make(map[string]string)
    if csv == "" {
        return out, nil
    }
    for _, entry := range strings.Split(csv, ",") {
        entry = strings.TrimSpace(entry)
        if entry == "" {
            continue
        }
        colon := strings.IndexByte(entry, ':')
        if colon < 0 {
            return nil, fmt.Errorf("entry %q missing colon
                separator", entry)
        }
        name := entry[:colon]
        uuidStr := entry[colon+1:]
        uuidBytes, err := parseUUID(uuidStr)
        if err != nil {
            return nil, fmt.Errorf("entry %q: %w", entry, err)
        }
    }
}

```

```

        h := hmac.New(sha256.New, secret)
        h.Write(uuidBytes)
        for i := range uuidBytes {
            uuidBytes[i] = 0
        }
        out[hex.EncodeToString(h.Sum(nil))] = name
    }
    return out, nil
}

func parseUUID(s string) ([]byte, error) {
    s = strings.ReplaceAll(s, "-", "")
    if len(s) != 32 {
        return nil, fmt.Errorf("UUID %q wrong length", s)
    }
    out := make([]byte, 16)
    for i := 0; i < 16; i++ {
        b, err := strconv.ParseUint(s[i*2:i*2+2], 16, 8)
        if err != nil {
            return nil, fmt.Errorf("UUID %q malformed: %w", s, err)
        }
        out[i] = byte(b)
    }
    return out, nil
}

func parseBackoffSteps(csv string) ([]time.Duration, error) {
    parts := strings.Split(csv, ",")
    out := make([]time.Duration, 0, len(parts))
    var prev time.Duration
    for _, p := range parts {
        p = strings.TrimSpace(p)
        d, err := time.ParseDuration(p)
        if err != nil {
            return nil, fmt.Errorf("step %q: %w", p, err)
        }
        if d < prev {
            return nil, fmt.Errorf("steps not monotonically non-decreasing at %q (prev %s)", p, prev)
        }
        prev = d
        out = append(out, d)
    }
    if len(out) == 0 {
        return nil, errors.New("at least one step required")
    }
    return out, nil
}

func parseCSV(s string) []string {
    if s == "" {

```

```

        return nil
    }
    out := strings.Split(s, ",")
    for i := range out {
        out[i] = strings.TrimSpace(out[i])
    }
    return out
}

func envBool(key string, def bool) bool {
    v := os.Getenv(key)
    if v == "" {
        return def
    }
    b, err := strconv.ParseBool(v)
    if err != nil {
        return def
    }
    return b
}

```

Add imports at top: crypto/hmac, crypto/sha256, encoding/base64, encoding/hex, strconv, strings, time.



Step 2.2.4: Add config_test.go cases

In lava-api-go/internal/config/config_test.go, add:

```

func TestParseClientsList_ValidEntry(t *testing.T) {
    secret := []byte("test-secret-1234")
    m, err :=
        parseClientsList("android-1.2.7-1027:000000000-0000-0000-0000-000000000001",
            secret)
    if err != nil {
        t.Fatalf("unexpected error: %v", err)
    }
    if len(m) != 1 {
        t.Fatalf("expected 1 entry, got %d", len(m))
    }
    var name string
    for _, n := range m {
        name = n
    }
    if name != "android-1.2.7-1027" {
        t.Fatalf("name = %q", name)
    }
}

func TestParseClientsList_MissingColon(t *testing.T) {
    _, err := parseClientsList("notavalidentry", []byte("k"))
    if err == nil {

```

```

        t.Fatalf("expected error")
    }
}

func TestParseBackoffSteps_Valid(t *testing.T) {
    steps, err := parseBackoffSteps("2s,5s,10s")
    if err != nil {
        t.Fatalf("err: %v", err)
    }
    if len(steps) != 3 {
        t.Fatalf("len = %d", len(steps))
    }
    if steps[0] != 2*time.Second {
        t.Fatalf("steps[0] = %s", steps[0])
    }
}

func TestParseBackoffSteps_NotMonotonic(t *testing.T) {
    _, err := parseBackoffSteps("10s,5s")
    if err == nil {
        t.Fatalf("expected error")
    }
}

```



Step 2.2.5: Run go test

```
cd lava-api-go && go test ./internal/config/...
```



Step 2.2.6: Falsifiability rehearsal — break parseBackoffSteps

```

# Remove the "not monotonically" check from parseBackoffSteps
sed -i 's|return nil, fmt.Errorf("steps not monotonically.*|//&|'
    \
    internal/config/config.go
go test ./internal/config/... -run
    TestParseBackoffSteps_NotMonotonic
# Expected: FAIL — the test now passes a non-monotonic input
    without error
git checkout internal/config/config.go

```

Record the observed failure for Bluff-Audit.



Step 2.2.7: Commit

```

cd /run/media/milosvasic/DATA4TB/Projects/Lava
git add lava-api-go/internal/config/config.go lava-api-go/
    internal/config/config_test.go
git commit -m "$(cat <<'EOF'
config(api-go): Phase 1 auth + transport fields

```

```
Adds the LAVA_AUTH_* + LAVA_API_BROTLI_* + LAVA_API_HTTP3_* fields
to
internal/config/config.Config; Load() reads + validates each per
spec
§5. Helper functions:
- parseClientsList: parses "name:uuid,..." into map[hash]name with
  HMAC-SHA256 hashing + plaintext UUID zeroize
- parseBackoffSteps: parses CSV durations, enforces monotonic
  non-decreasing
- parseUUID: hex-decodes a 36-char UUID into 16 bytes

Bluff-Audit: TestParseBackoffSteps_NotMonotonic
  Mutation: commented out the monotonic check in parseBackoffSteps
  Observed-Failure: TestParseBackoffSteps_NotMonotonic FAIL
                  "expected error" with no error

  Reverted: yes

Co-Authored-By: Claude Opus 4.7 (1M context)
                <noreply@anthropic.com>
EOF
)"
```

Phase 3: submodules/ratelimiter pkg/ ladder upstream contribution

Task 3.1: Investigate RateLimiter test conventions

Files: Read-only.



Step 3.1.1: Read existing pattern

```
ls submodules/ratelimiter/pkg/tokenbucket/
sed -n '1,30p' submodules/ratelimiter/pkg/tokenbucket/
tokenbucket.go
sed -n '1,30p' submodules/ratelimiter/pkg/tokenbucket/
tokenbucket_test.go
```

Note the exported types, godoc comment style, test naming convention.

Task 3.2: Write pkg/ladder failing test (TDD)

Files:

- Create: submodules/ratelimiter/pkg/ladder/ladder_test.go



Step 3.2.1: Write the test file

```
// Package ladder_test exercises the per-key fixed-ladder backoff
// state
// machine.
package ladder_test

import (
    "testing"
    "time"

    "github.com/vasic-digital/RateLimiter/pkg/ladder"
)

func TestLadder_FirstFailure_ReturnsFirstStep(t *testing.T) {
    l := ladder.New([]time.Duration{2 * time.Second, 5 *
        time.Second})
    duration := l.RecordFailure("ip-a", time.Unix(1000, 0))
    if duration != 2*time.Second {
        t.Fatalf("expected 2s, got %s", duration)
    }
}

func TestLadder_SecondFailure_AdvancesToSecondStep(t *testing.T) {
    l := ladder.New([]time.Duration{2 * time.Second, 5 *
        time.Second})
    l.RecordFailure("ip-a", time.Unix(1000, 0))
    duration := l.RecordFailure("ip-a", time.Unix(1010, 0))
    if duration != 5*time.Second {
        t.Fatalf("expected 5s, got %s", duration)
    }
}

func TestLadder_BeyondLastStep_ClampsToLastStep(t *testing.T) {
    l := ladder.New([]time.Duration{2 * time.Second, 5 *
        time.Second})
    l.RecordFailure("ip-a", time.Unix(1000, 0))
    l.RecordFailure("ip-a", time.Unix(1010, 0))
    duration := l.RecordFailure("ip-a", time.Unix(1020, 0))
    if duration != 5*time.Second {
        t.Fatalf("expected 5s clamp, got %s", duration)
    }
}

func TestLadder_Reset_ClearsCounter(t *testing.T) {
    l := ladder.New([]time.Duration{2 * time.Second, 5 *
        time.Second})
    l.RecordFailure("ip-a", time.Unix(1000, 0))
    l.RecordFailure("ip-a", time.Unix(1010, 0))
    l.Reset("ip-a")
    duration := l.RecordFailure("ip-a", time.Unix(1020, 0))
    if duration != 2*time.Second {
        t.Fatalf("expected 2s after reset, got %s", duration)
    }
}
```



```

    }
}

func TestLadder_CheckBlocked_BeforeFailure_NotBlocked(t
    *testing.T) {
    l := ladder.New([]time.Duration{2 * time.Second})
    blocked, _ := l.CheckBlocked("ip-a", time.Unix(1000, 0))
    if blocked {
        t.Fatal("expected not blocked")
    }
}

func TestLadder_CheckBlocked_AfterFailure_BlockedForDuration(t
    *testing.T) {
    l := ladder.New([]time.Duration{2 * time.Second})
    l.RecordFailure("ip-a", time.Unix(1000, 0))
    blocked, retryAfter := l.CheckBlocked("ip-a", time.Unix(1001,
        0))
    if !blocked {
        t.Fatal("expected blocked")
    }
    if retryAfter != 1*time.Second {
        t.Fatalf("expected 1s retry-after, got %s", retryAfter)
    }
}

func TestLadder_CheckBlocked_AfterExpiry_NotBlocked(t *testing.T)
    {
        l := ladder.New([]time.Duration{2 * time.Second})
        l.RecordFailure("ip-a", time.Unix(1000, 0))
        blocked, _ := l.CheckBlocked("ip-a", time.Unix(1003, 0))
        if blocked {
            t.Fatal("expected not blocked after expiry")
        }
    }

func TestLadder_New_RejectsEmpty(t *testing.T) {
    defer func() {
        if r := recover(); r == nil {
            t.Fatal("expected panic for empty steps")
        }
    }()
    ladder.New(nil)
}

func TestLadder_PerKeyIndependence(t *testing.T) {
    l := ladder.New([]time.Duration{2 * time.Second, 5 *
        time.Second})
    l.RecordFailure("ip-a", time.Unix(1000, 0))
    duration := l.RecordFailure("ip-b", time.Unix(1000, 0))
    if duration != 2*time.Second {
        t.Fatalf("ip-b should be at step 0; got %s", duration)
    }
}

```

```
}  
}
```



Step 3.2.2: Run; verify all fail because package doesn't exist

```
cd submodules/ratelimiter && go test ./pkg/ladder/...
```

Expected: package not found.

Task 3.3: Implement pkg/ladder

Files:

- Create: submodules/ratelimiter/pkg/ladder/ladder.go



Step 3.3.1: Write the implementation

```
// Package ladder implements a per-key fixed-step backoff state  
// machine.  
//  
// On each failure for a given key, the ladder advances by one  
// step,  
// clamping at the last step. CheckBlocked reports whether the key  
// is  
// currently blocked AND the remaining retry-after duration.  
//  
// State is held in-memory via a sync.Map keyed by an opaque  
// string  
// (typically a client IP). Memory grows with the number of  
// distinct  
// failing keys; callers SHOULD periodically Prune entries whose  
// blockedUntil + retentionTTL has passed.  
//  
// Use case: HTTP auth middleware that progressively delays  
// retries  
// from a misbehaving source. See lava-api-go/internal/auth/  
// backoff.go  
// for the canonical Lava-side wrapper.  
package ladder  
  
import (  
    "sync"  
    "time"  
)  
  
// Ladder is a per-key fixed-step backoff state machine.  
type Ladder struct {  
    steps []time.Duration  
    state sync.Map // key string → *entry  
}
```

```

type entry struct {
    mu          sync.Mutex
    failures    int
    blockedUntil time.Time
}

// New constructs a Ladder with the given step durations.
// Panics if steps is empty.
func New(steps []time.Duration) *Ladder {
    if len(steps) == 0 {
        panic("ladder.New: steps must be non-empty")
    }
    cp := make([]time.Duration, len(steps))
    copy(cp, steps)
    return &Ladder{steps: cp}
}

// RecordFailure advances the failure counter for key and returns
// the
// duration to block for. Failures past the last step clamp to it.
func (l *Ladder) RecordFailure(key string, now time.Time)
    time.Duration {
    e := l.lookup(key)
    e.mu.Lock()
    defer e.mu.Unlock()
    if e.failures < len(l.steps) {
        e.failures++
    }
    duration := l.steps[e.failures-1]
    e.blockedUntil = now.Add(duration)
    return duration
}

// Reset clears the counter for key.
func (l *Ladder) Reset(key string) {
    l.state.Delete(key)
}

// CheckBlocked reports whether key is currently blocked and how
// long
// until retry is allowed.
func (l *Ladder) CheckBlocked(key string, now time.Time) (bool,
    time.Duration) {
    raw, ok := l.state.Load(key)
    if !ok {
        return false, 0
    }
    e := raw.(*entry)
    e.mu.Lock()
    defer e.mu.Unlock()
    if now.Before(e.blockedUntil) {

```

```

        return true, e.blockedUntil.Sub(now)
    }
    return false, 0
}

// Prune removes entries whose blockedUntil + retention has
// passed.
// Caller is expected to invoke this periodically to bound memory.
func (l *Ladder) Prune(now time.Time, retention time.Duration)
    int {
    pruned := 0
    cutoff := now.Add(-retention)
    l.state.Range(func(k, v interface{}) bool {
        e := v.(*entry)
        e.mu.Lock()
        expired := e.blockedUntil.Before(cutoff)
        e.mu.Unlock()
        if expired {
            l.state.Delete(k)
            pruned++
        }
        return true
    })
    return pruned
}

func (l *Ladder) lookup(key string) *entry {
    raw, _ := l.state.LoadOrStore(key, &entry{})
    return raw.(*entry)
}

```



Step 3.3.2: Run tests; verify all pass

```
cd submodules/ratelimiter && go test ./pkg/ladder/...
```



Step 3.3.3: Falsifiability rehearsal — break Reset

```

# Make Reset a no-op
sed -i 's|l.state.Delete(key)|// l.state.Delete(key) -- mutated|'
\
pkg/ladder/ladder.go
go test ./pkg/ladder/... -run TestLadder_Reset_ClearsCounter
# Expected: FAIL — duration after reset is 5s, not 2s
git checkout pkg/ladder/ladder.go
go test ./pkg/ladder/...
# Expected: PASS

```



Step 3.3.4: Commit in the submodule

```
cd submodules/ratelimiter
git add pkg/ladder/
git commit -m "$(cat <<'EOF'
feat(ladder): per-key fixed-step backoff state machine
```

Use case: HTTP auth middleware progressively delays retries from a misbehaving source. The Lava project (consumer) needs this primitive for its API auth backoff (see Lava project Phase 1 spec docs/superpowers/specs/2026-05-06-phase1-api-auth-design.md §6 + §13).

API:

- New(steps []time.Duration) *Ladder – panics on empty steps
- RecordFailure(key, now) → duration (clamps at last step)
- CheckBlocked(key, now) → (blocked, retryAfter)
- Reset(key) – clears counter
- Prune(now, retention) → int – bounds memory

State: per-key sync.Map[string]*entry; per-entry mutex for failure counter advancement.

Bluff-Audit: TestLadder_Reset_ClearsCounter

Mutation: Reset() became no-op (l.state.Delete commented out)

Observed-Failure: "expected 2s after reset, got 5s"

Reverted: yes

Co-Authored-By: Claude Opus 4.7 (1M context)

<noreply@anthropic.com>

EOF

)"

Task 3.4: Push the submodule + pin in Lava

Files:

- Modify: submodules/ratelimiter pin in Lava parent



Step 3.4.1: Push to RateLimiter mirrors

```
cd submodules/ratelimiter
for r in github gitlab gitflic gitverse; do
  git push $r master 2>&1 | tail -3
done
```



Step 3.4.2: Update Lava's pin

```
cd /run/media/milosvasic/DATA4TB/Projects/Lava
git submodule update --remote submodules/ratelimiter
```

```
# OR explicitly:  
# (cd submodules/ratelimiter && git rev-parse HEAD) gives the new  
  pin
```



Step 3.4.3: Verify Lava parent sees new pin

```
cd submodules/ratelimiter && git rev-parse HEAD  
cd ../../..  
git status  
# Expected: submodules/ratelimiter shows as modified (new commit  
  pin)
```



Step 3.4.4: Commit Lava parent pin update

```
git add submodules/ratelimiter  
git commit -m "deps(RateLimiter): pin pkg/ladder upstream  
  contribution"
```

Pins submodules/ratelimiter at the commit that introduces
pkg/ladder/ — the per-key fixed-step backoff primitive consumed by
lava-api-go's auth backoff middleware (Phase 1).

Co-Authored-By: Claude Opus 4.7 (1M context)
<noreply@anthropic.com>

Phase 4: API auth allowlist parser (already integrated into Phase 2 config layer)

The parseClientsList and parseUUID helpers live in internal/config/
config.go per Phase 2 — no separate file needed. The exported
Config.AuthActiveClients and AuthRetiredClients are the interfaces
consumed by Phase 5.

(No tasks in this phase — work is folded into Phase 2.)

Phase 5: API auth middleware

Task 5.1: Write failing tests for AuthMiddleware

Files:

- Create: lava-api-go/internal/auth/middleware_test.go



Step 5.1.1: Write tests

```
package auth_test

import (
    "encoding/base64"
    "encoding/hex"
    "net/http"
    "net/http/httptest"
    "testing"
    "time"

    "github.com/gin-gonic/gin"
    "github.com/vasic-digital/RateLimiter/pkg/ladder"

    "digital.vasic.lava.apigo/internal/auth"
    "digital.vasic.lava.apigo/internal/config"
)

// helper: build a base64-encoded raw 16-byte UUID payload from a
//          hex string.
func uuidBlob(t *testing.T, hexStr string) string {
    t.Helper()
    b, err := hex.DecodeString(hexStr)
    if err != nil {
        t.Fatalf("hex decode: %v", err)
    }
    return base64.StdEncoding.EncodeToString(b)
}

// helper: hash a raw 16-byte UUID as the parser would.
// Returns the hex-encoded hash (matches map keys in
//          cfg.AuthActiveClients).
func hashUUID(secret []byte, hexStr string) string {
    b, _ := hex.DecodeString(hexStr)
    return auth.TestOnlyHashUUID(secret, b) // see middleware.go
                                           // for export
}

func TestAuthMiddleware_ActiveUuid_Returns200(t *testing.T) {
    gin.SetMode(gin.TestMode)
    secret := []byte("test-secret-1234")
    activeUUID := "00000000000000000000000000000001"
    cfg := &config.Config{
        AuthFieldName: "Lava-Auth",
        AuthHMACSecret: secret,
        AuthActiveClients: map[string]string{hashUUID(secret,
            activeUUID): "android-test"},
    }
    l := ladder.New([]time.Duration{1 * time.Second})
    mw := auth.NewMiddleware(cfg, l)

    r := gin.New()
```

```

r.Use(mw)
r.GET("/x", func(c *gin.Context) { c.Status(http.StatusOK) })

req := httptest.NewRequest("GET", "/x", nil)
req.Header.Set("Lava-Auth", uuidBlob(t, activeUUID))
w := httptest.NewRecorder()
r.ServeHTTP(w, req)

if w.Code != http.StatusOK {
    t.Fatalf("status = %d, want 200", w.Code)
}
}

func TestAuthMiddleware_RetiredUuid_Returns426(t *testing.T) {
    gin.SetMode(gin.TestMode)
    secret := []byte("test-secret-1234")
    retiredUUID := "00000000000000000000000000000000"
    cfg := &config.Config{
        AuthFieldName:      "Lava-Auth",
        AuthHMACSecret:      secret,
        AuthActiveClients:   map[string]string{},
        AuthRetiredClients:  map[string]string{hashUUID(secret, retiredUUID): "android-old"},
        AuthMinSupportedVersionName: "1.2.6",
        AuthMinSupportedVersionCode: 1026,
    }
    l := ladder.New([]time.Duration{1 * time.Second})
    mw := auth.NewMiddleware(cfg, l)

    r := gin.New()
    r.Use(mw)
    r.GET("/x", func(c *gin.Context) { c.Status(http.StatusOK) })

    req := httptest.NewRequest("GET", "/x", nil)
    req.Header.Set("Lava-Auth", uuidBlob(t, retiredUUID))
    w := httptest.NewRecorder()
    r.ServeHTTP(w, req)

    if w.Code != 426 {
        t.Fatalf("status = %d, want 426", w.Code)
    }
    body := w.Body.String()
    if !strings.Contains(body,
        `"min_supported_version_name":"1.2.6"`) {
        t.Fatalf("body missing min_supported_version_name: %s",
            body)
    }
    if !strings.Contains(body,
        `"min_supported_version_code":1026`) {
        t.Fatalf("body missing min_supported_version_code: %s",
            body)
    }
}

```



```

}

func TestAuthMiddleware_UnknownUuid_Returns401_AndIncrementsBackoff(t
    *testing.T) {
    gin.SetMode(gin.TestMode)
    secret := []byte("test-secret-1234")
    cfg := &config.Config{
        AuthFieldName:      "Lava-Auth",
        AuthHMACSecret:      secret,
        AuthActiveClients:   map[string]string{},
    }
    l := ladder.New([]time.Duration{1 * time.Second, 5 *
        time.Second})
    mw := auth.NewMiddleware(cfg, l)

    r := gin.New()
    r.Use(mw)
    r.GET("/x", func(c *gin.Context) { c.Status(http.StatusOK) })

    req := httptest.NewRequest("GET", "/x", nil)
    req.Header.Set("Lava-Auth", uuidBlob(t,
        "ffffffffffffffffffffffffffffffff"))
    req.RemoteAddr = "192.0.2.1:1234"
    w := httptest.NewRecorder()
    r.ServeHTTP(w, req)
    if w.Code != 401 {
        t.Fatalf("status = %d, want 401", w.Code)
    }

    // Second request from same IP should now be at step 2 (5s)
    blocked, retryAfter := l.CheckBlocked("192.0.2.1", time.Now())
    if !blocked {
        t.Fatal("expected blocked after 401")
    }
    if retryAfter > 1*time.Second {
        t.Fatalf("retryAfter = %s; counter advanced too
            aggressively", retryAfter)
    }
}

func TestAuthMiddleware_MissingHeader_Returns401(t *testing.T) {
    gin.SetMode(gin.TestMode)
    cfg := &config.Config{
        AuthFieldName:      "Lava-Auth",
        AuthHMACSecret:      []byte("k"),
        AuthActiveClients:   map[string]string{},
    }
    l := ladder.New([]time.Duration{1 * time.Second})
    mw := auth.NewMiddleware(cfg, l)

    r := gin.New()
    r.Use(mw)

```

```

    r.GET("/x", func(c *gin.Context) { c.Status(http.StatusOK) })

    req := httptest.NewRequest("GET", "/x", nil)
    w := httptest.NewRecorder()
    r.ServeHTTP(w, req)

    if w.Code != 401 {
        t.Fatalf("status = %d, want 401", w.Code)
    }
}

func TestAuthMiddleware_MalformedBase64_Returns401(t *testing.T) {
    gin.SetMode(gin.TestMode)
    cfg := &config.Config{
        AuthFieldName:      "Lava-Auth",
        AuthHMACSecret:      []byte("k"),
        AuthActiveClients:  map[string]string{},
    }
    l := ladder.New([]time.Duration{1 * time.Second})
    mw := auth.NewMiddleware(cfg, l)

    r := gin.New()
    r.Use(mw)
    r.GET("/x", func(c *gin.Context) { c.Status(http.StatusOK) })

    req := httptest.NewRequest("GET", "/x", nil)
    req.Header.Set("Lava-Auth", "!!!not-base64!!!")
    w := httptest.NewRecorder()
    r.ServeHTTP(w, req)

    if w.Code != 401 {
        t.Fatalf("status = %d, want 401", w.Code)
    }
}

```

Add import "strings" at top.



Step 5.1.2: Run; verify all fail (package not yet implemented)

```

cd lava-api-go && go test ./internal/auth/... -run
    'TestAuthMiddleware'

```

Expected: compilation error (auth.NewMiddleware undefined).

Task 5.2: Implement AuthMiddleware

Files:

- Create: lava-api-go/internal/auth/middleware.go



Step 5.2.1: Write middleware

```
// Package auth implements Lava-API-Go authentication middleware.
//
// AuthMiddleware verifies the Lava-Auth header against the active
// and
// retired allowlists configured at boot. Active hashes pass;
// retired
// hashes return 426 Upgrade Required (no backoff increment);
// unknown
// hashes return 401 (backoff counter advances).
//
// The middleware DEPENDS on a *ladder.Ladder for backoff state –
// see
// internal/auth/backoff.go for the BackoffMiddleware that
// consumes the
// same Ladder in front of this one.
package auth

import (
    "crypto/hmac"
    "crypto/sha256"
    "crypto/subtle"
    "encoding/base64"
    "encoding/hex"
    "net/http"

    "github.com/gin-gonic/gin"
    "github.com/vasic-digital/RateLimiter/pkg/ladder"

    "digital.vasic.lava.apigo/internal/config"
)

// NewMiddleware returns a Gin handler that enforces Lava-Auth on
// every
// request. The Ladder is shared with BackoffMiddleware; on 401
// the
// counter advances, on 200 it resets.
func NewMiddleware(cfg *config.Config, l *ladder.Ladder)
    gin.HandlerFunc {
    fieldName := cfg.AuthFieldName
    secret := cfg.AuthHMACSecret
    active := cfg.AuthActiveClients
    retired := cfg.AuthRetiredClients

    return func(c *gin.Context) {
        hdr := c.GetHeader(fieldName)
        if hdr == "" {
            c.AbortWithStatusJSON(http.StatusUnauthorized,
                gin.H{"error": "unauthorized"})
            return
        }
    }
}
```

```

blob, err := base64.StdEncoding.DecodeString(hdr)
if err != nil || len(blob) == 0 {
    c.AbortWithStatusJSON(http.StatusUnauthorized,
        gin.H{"error": "unauthorized"})
    return
}

hash := hashUUIDBlob(secret, blob)
for i := range blob {
    blob[i] = 0
}

if name, ok := constantTimeMapLookup(active, hash); ok {
    c.Set("client_name", name)
    l.Reset(c.ClientIP())
    c.Next()
    return
}

if name, ok := constantTimeMapLookup(retired, hash); ok {
    c.JSON(http.StatusUpgradeRequired, gin.H{
        "error":
            "client_version_unsupported",
        "client_name":
            name,
        "min_supported_version_name":
            cfg.AuthMinSupportedVersionName,
        "min_supported_version_code":
            cfg.AuthMinSupportedVersionCode,
    })
    c.Abort()
    return
}

// Unknown UUID: advance backoff, return 401.
l.RecordFailure(c.ClientIP(),
    c.Request.Context().Value(timeKey{}).(timeProvider).Now())
c.AbortWithStatusJSON(http.StatusUnauthorized,
    gin.H{"error": "unauthorized"})
}
}

// constantTimeMapLookup is a constant-time variant of map lookup
    against
    // the known set of hashes – iterates ALL entries on every call.
    This
    // matters for timing side-channels: a regular map lookup would
    short-
    // circuit on hash mismatch, leaking information about which
    buckets
    // the attacker's hash collides with.
func constantTimeMapLookup(m map[string]string, hash string)
    (string, bool) {
    var foundName string
    var found int

```

```

    for k, v := range m {
        eq := subtle.ConstantTimeCompare([]byte(k), []byte(hash))
        if eq == 1 {
            foundName = v
            found = 1
        }
    }
    return foundName, found == 1
}

func hashUUIDBlob(secret, blob []byte) string {
    h := hmac.New(sha256.New, secret)
    h.Write(blob)
    return hex.EncodeToString(h.Sum(nil))
}

// TestOnlyHashUUID is exported for tests in middleware_test.go to
// pre-compute hashes for fixture allowlists.
func TestOnlyHashUUID(secret, blob []byte) string {
    return hashUUIDBlob(secret, blob)
}

```

Note: the time provider abstraction is for testability of backoff timing — implement minimally:

```

// timeKey is a context key used by BackoffMiddleware to pass a
// custom
// time provider; auth tests inject a fake clock here.
type timeKey struct{}

type timeProvider interface {
    Now() time.Time
}

```

For Phase 5 simplicity, just use `time.Now()` directly:

Replace

```
l.RecordFailure(c.ClientIP(),
    c.Request.Context().Value(timeKey{}).(timeProvider).Now())
```

with

```
l.RecordFailure(c.ClientIP(), time.Now())
```

Add `import "time".`



Step 5.2.2: Run tests

```
cd lava-api-go && go test ./internal/auth/... -run
    'TestAuthMiddleware'
```



Step 5.2.3: Falsifiability rehearsal — break retired-UUID branch

```
# Make retired branch fall through to 401 instead of 426
sed -i 's|c.JSON(http.StatusUpgradeRequired,|
    c.JSON(http.StatusUnauthorized, // mutation:|' \
    internal/auth/middleware.go
go test ./internal/auth/... -run
    TestAuthMiddleware_RetiredUuid_Returns426
# Expected: FAIL - status=401 != 426
git checkout internal/auth/middleware.go
go test ./internal/auth/... -run 'TestAuthMiddleware'
# Expected: all PASS
```



Step 5.2.4: Commit

```
cd /run/media/milosvasic/DATA4TB/Projects/Lava
git add lava-api-go/internal/auth/middleware.go lava-api-go/
    internal/auth/middleware_test.go
git commit -m "$(cat <<'EOF'
feat(auth): NewMiddleware enforces Lava-Auth header (active/
    retired/unknown)
```

AuthMiddleware verifies the Lava-Auth header against active and retired

allowlists configured at boot:

- Active hash: c.Next() + ladder.Reset(ip)
- Retired hash: 426 Upgrade Required + min_supported_version_{name,code}
- Unknown hash / missing header / malformed base64: 401 + ladder.RecordFailure

Constant-time map lookup (subtle.ConstantTimeCompare) iterates ALL entries on every call to defeat timing side-channels.

Plaintext blob bytes zeroized after hashing.

Bluff-Audit: TestAuthMiddleware_RetiredUuid_Returns426
Mutation: retired branch returned 401 instead of 426
Observed-Failure: "status = 401, want 426"
Reverted: yes

Co-Authored-By: Claude Opus 4.7 (1M context)
<noreply@anthropic.com>

EOF
)"

Phase 6: API backoff middleware (Lava-side wrapper over RateLimiter)

Task 6.1: Write failing tests for BackoffMiddleware

Files:

- Create: lava-api-go/internal/auth/backoff_test.go



Step 6.1.1: Write tests

```
package auth_test
```

```
import (
    "fmt"
    "net/http"
    "net/http/httptest"
    "strconv"
    "testing"
    "time"

    "github.com/gin-gonic/gin"
    "github.com/vasic-digital/RateLimiter/pkg/ladder"

    "digital.vasic.lava.apigo/internal/auth"
)

func TestBackoffMiddleware_NotBlocked_PassesThrough(t *testing.T)
{
    gin.SetMode(gin.TestMode)
    l := ladder.New([]time.Duration{1 * time.Second})
    mw := auth.NewBackoffMiddleware(l, nil)

    r := gin.New()
    r.Use(mw)
    r.GET("/x", func(c *gin.Context) { c.Status(http.StatusOK) })

    req := httptest.NewRequest("GET", "/x", nil)
    req.RemoteAddr = "192.0.2.1:1234"
    w := httptest.NewRecorder()
    r.ServeHTTP(w, req)

    if w.Code != http.StatusOK {
        t.Fatalf("status = %d, want 200", w.Code)
    }
}

func TestBackoffMiddleware_Blocked_Returns429WithRetryAfter(t
    *testing.T) {
    gin.SetMode(gin.TestMode)
```

```

l := ladder.New([]time.Duration{30 * time.Second})
l.RecordFailure("192.0.2.1", time.Now())
mw := auth.NewBackoffMiddleware(l, nil)

r := gin.New()
r.Use(mw)
r.GET("/x", func(c *gin.Context) { c.Status(http.StatusOK) })

req := httptest.NewRequest("GET", "/x", nil)
req.RemoteAddr = "192.0.2.1:1234"
w := httptest.NewRecorder()
r.ServeHTTP(w, req)

if w.Code != http.StatusTooManyRequests {
    t.Fatalf("status = %d, want 429", w.Code)
}
retryAfter := w.Header().Get("Retry-After")
n, err := strconv.Atoi(retryAfter)
if err != nil {
    t.Fatalf("Retry-After = %q (not an integer)", retryAfter)
}
if n < 25 || n > 30 {
    t.Fatalf("Retry-After = %d; expected ~30s", n)
}
}

func TestBackoffMiddleware_BlockedHonorsTrustedProxies(t
    *testing.T) {
    gin.SetMode(gin.TestMode)
    l := ladder.New([]time.Duration{30 * time.Second})
    // Pretend "10.0.0.1" is the trusted proxy; record failure for
    // the
    // X-Forwarded-For client IP.
    l.RecordFailure("203.0.113.5", time.Now())
    mw := auth.NewBackoffMiddleware(l, []string{"10.0.0.1/32"})

    r := gin.New()
    r.Use(mw)
    r.GET("/x", func(c *gin.Context) { c.Status(http.StatusOK) })

    req := httptest.NewRequest("GET", "/x", nil)
    req.Header.Set("X-Forwarded-For", "203.0.113.5")
    req.RemoteAddr = "10.0.0.1:1234"
    w := httptest.NewRecorder()
    r.ServeHTTP(w, req)

    if w.Code != http.StatusTooManyRequests {
        t.Fatalf("status = %d, want 429 (trusted proxy unwrapping
            failed)", w.Code)
    }
}

```



```

    // Note: the `fmt` import keeps the compiler quiet if other
    // tests use it.
    _ = fmt.Sprintf("")
}

```



Step 6.1.2: Run; verify fail (NewBackoffMiddleware undefined)

```

cd lava-api-go && go test ./internal/auth/... -run
    TestBackoffMiddleware

```

Task 6.2: Implement BackoffMiddleware

Files:

- Create: lava-api-go/internal/auth/backoff.go



Step 6.2.1: Write implementation

```

package auth

```

```

import (
    "fmt"
    "math"
    "net"
    "net/http"
    "strings"
    "time"

    "github.com/gin-gonic/gin"
    "github.com/vasic-digital/RateLimiter/pkg/ladder"
)

```

```

// NewBackoffMiddleware returns a Gin handler that returns 429 +
// Retry-After when the client IP is currently blocked by the
// ladder.
// On pass-through, the inner AuthMiddleware decides 200/401/426.
//
// trustedProxies is a list of CIDRs; when c.RemoteAddr matches
// one of
// them, the X-Forwarded-For header's first non-trusted hop is
// used as
// the client IP for ladder lookup.
func NewBackoffMiddleware(l *ladder.Ladder, trustedProxies
    []string) gin.HandlerFunc {
    nets := parseCIDRs(trustedProxies)
    return func(c *gin.Context) {
        ip := resolveClientIP(c, nets)
        c.Set("client_ip_resolved", ip)
        blocked, retryAfter := l.CheckBlocked(ip, time.Now())
    }
}

```

```

    if blocked {
        seconds := int(math.Ceil(retryAfter.Seconds()))
        c.Header("Retry-After", fmt.Sprintf("%d", seconds))
        c.AbortWithStatusJSON(http.StatusTooManyRequests,
            gin.H{
                "error": "rate_limited",
                "retry_after_seconds": seconds,
            })
        return
    }
    c.Next()
}

func resolveClientIP(c *gin.Context, trusted []*net.IPNet) string
{
    remote, _, err := net.SplitHostPort(c.Request.RemoteAddr)
    if err != nil {
        remote = c.Request.RemoteAddr
    }
    rIP := net.ParseIP(remote)
    if rIP == nil {
        return remote
    }
    for _, n := range trusted {
        if n.Contains(rIP) {
            xff := c.GetHeader("X-Forwarded-For")
            if xff != "" {
                first := strings.SplitN(xff, ",", 2)[0]
                return strings.TrimSpace(first)
            }
        }
    }
    return remote
}

func parseCIDRs(s []string) []*net.IPNet {
    out := make([]*net.IPNet, 0, len(s))
    for _, c := range s {
        c = strings.TrimSpace(c)
        if c == "" {
            continue
        }
        _, n, err := net.ParseCIDR(c)
        if err != nil {
            continue
        }
        out = append(out, n)
    }
    return out
}

```



Step 6.2.2: Run tests

```
cd lava-api-go && go test ./internal/auth/... -run
TestBackoffMiddleware
```



Step 6.2.3: Falsifiability rehearsal — break trusted-proxy unwrap

```
sed -i 's|return strings.TrimSpace(first)|return remote //
mutation|' internal/auth/backoff.go
go test ./internal/auth/... -run
TestBackoffMiddleware_BlockedHonorsTrustedProxies
# Expected: FAIL
git checkout internal/auth/backoff.go
go test ./internal/auth/... -run TestBackoffMiddleware
# Expected: PASS
```



Step 6.2.4: Commit

```
cd /run/media/milosvasic/DATA4TB/Projects/Lava
git add lava-api-go/internal/auth/backoff.go lava-api-go/internal/
auth/backoff_test.go
git commit -m "$(cat <<'EOF'
feat(auth): NewBackoffMiddleware (429 + Retry-After) wrapping pkg/
ladder
```

```
Lava-side glue over submodules/ratelimiter/pkg/ladder. Resolves
client
```

```
IP honoring trusted-proxy CIDRs (X-Forwarded-For unwrap). On
block:
```

```
returns 429 with Retry-After integer-seconds header + JSON body
{error: "rate_limited", retry_after_seconds: N}.
```

```
Bluff-Audit: TestBackoffMiddleware_BlockedHonorsTrustedProxies
Mutation: trusted-proxy unwrap returned RemoteAddr instead of
XFF
```

```
Observed-Failure: "status = 200, want 429 (trusted proxy
unwrapping failed)"
```

```
Reverted: yes
```

```
Co-Authored-By: Claude Opus 4.7 (1M context)
<noreply@anthropic.com>
```

```
EOF
)"
```

Phase 7: Wire middlewares + integration tests

Task 7.1: Wire backoff + auth in cmd/lava-api-go/main.go

Files:

- Modify: lava-api-go/cmd/lava-api-go/main.go
- Modify: lava-api-go/internal/server/server.go (likely; pattern depends on existing structure)



Step 7.1.1: Read existing main + server

```
sed -n '1,80p' lava-api-go/cmd/lava-api-go/main.go
sed -n '1,80p' lava-api-go/internal/server/server.go
```



Step 7.1.2: Wire middlewares in main.go boot

Locate where the Gin engine is constructed (likely in internal/server/server.go's NewEngine or equivalent). Inject the new middlewares BEFORE existing handlers:

```
import (
    // existing
    "github.com/vasic-digital/RateLimiter/pkg/ladder"
    "digital.vasic.lava.apigo/internal/auth"
)

// in NewEngine() or main():
backoffLadder := ladder.New(cfg.AuthBackoffSteps)
backoffMW := auth.NewBackoffMiddleware(backoffLadder,
    cfg.AuthTrustedProxies)
authMW := auth.NewMiddleware(cfg, backoffLadder)

router.Use(backoffMW) // first: short-circuits blocked IPs
router.Use(authMW)   // second: enforces Lava-Auth on
                    // everything

// (existing handler registrations follow)
```



Step 7.1.3: Smoke-test

```
cd lava-api-go && go build ./...
```

Expected: clean build.



Step 7.1.4: Commit

```
git add lava-api-go/cmd/lava-api-go/main.go lava-api-go/internal/
server/server.go
git commit -m "feat(api): wire backoff + auth middlewares in boot
path"
```

Co-Authored-By: Claude Opus 4.7 (1M context)
<noreply@anthropic.com>

Task 7.2: §6.G integration tests (8 test files)

For each integration test below, the structure is identical:

1. Boot a real lava-api-go Gin engine via `httptest.NewServer` with realistic config
2. Issue a real HTTP request with the appropriate header/body
3. Assert on user-visible state (status code, response body, header presence)

Files for each test (Tasks 7.2.1 - 7.2.8): `lava-api-go/tests/integration/auth_<name>_test.go`



Step 7.2.1: `auth_active_uuid_test.go`

```
package integration_test
```

```
import (
    "encoding/base64"
    "encoding/hex"
    "net/http"
    "testing"

    // existing imports for test bootstrap
    "digital.vasic.lava.apigo/tests/integration/testenv"
)

func TestIntegration_AuthActiveUuid_Returns200(t *testing.T) {
    activeUUIDHex := "0000000000000000000000000000000001"
    env := testenv.NewWithAuth(t, testenv.AuthConfig{
        FieldName: "Lava-Auth",
        ActiveUUIDHex: []string{activeUUIDHex},
    })
    defer env.Close()

    blob, _ := hex.DecodeString(activeUUIDHex)
    headerVal := base64.StdEncoding.EncodeToString(blob)

    req, _ := http.NewRequest("GET", env.URL+"/api/v1/search?
q=test", nil)
    req.Header.Set("Lava-Auth", headerVal)
```

```

    resp, err := env.Client.Do(req)
    if err != nil {
        t.Fatalf("request error: %v", err)
    }
    defer resp.Body.Close()
    if resp.StatusCode != http.StatusOK {
        t.Fatalf("status = %d, want 200", resp.StatusCode)
    }
}

```

For tests 7.2.2 – 7.2.8 (retired UUID, unknown UUID, backoff ladder, backoff resets, brotli response, h3 alt-svc, protocol metric), use the same structure with the corresponding assertion. Each gets its own *_test.go file.

The testenv helper package (create at lava-api-go/tests/integration/testenv/) wraps httptest.NewServer with the required Config overrides. Expose:

```

package testenv

import (
    "crypto/rand"
    "net/http"
    "testing"

    "digital.vasic.lava.apigo/internal/auth"
    "digital.vasic.lava.apigo/internal/config"
    "digital.vasic.lava.apigo/internal/server"
)

type AuthConfig struct {
    FieldName      string
    ActiveUUIDHex  []string
    RetiredUUIDHex []string
    BackoffSteps   []time.Duration
}

type Env struct {
    URL      string
    Client   *http.Client
    Close    func()
}

func NewWithAuth(t *testing.T, ac AuthConfig) *Env {
    secret := make([]byte, 32)
    rand.Read(secret)
    cfg := &config.Config{
        AuthFieldName:      ac.FieldName,
        AuthHMACSecret:     secret,
        AuthActiveClients:  hashEntries(secret,
            ac.ActiveUUIDHex),
    }
    env := &Env{
        URL:      "http://localhost:8080",
        Client:   http.DefaultClient,
        Close:    func() {},
    }
    return env
}

```

```

        AuthRetiredClients:      hashEntries(secret,
        ac.RetiredUUIDHex),
        AuthBackoffSteps:        ac.BackoffStepsOrDefault(),
        AuthMinSupportedVersionName: "1.2.6",
        AuthMinSupportedVersionCode: 1026,
    }
    eng := server.NewEngine(cfg) // existing
    ts := httptest.NewServer(eng)
    return &Env{
        URL:      ts.URL,
        Client: ts.Client(),
        Close: ts.Close,
    }
}

func hashEntries(secret []byte, hexes []string) map[string]string
{
    out := make(map[string]string)
    for i, h := range hexes {
        b, _ := hex.DecodeString(h)
        out[auth.TestOnlyHashUUID(secret, b)] = fmt.Sprintf("test-
        %d", i)
    }
    return out
}

```



Step 7.2.2: auth_retired_uuid_test.go

Asserts 426 + body containing min_supported_version_name and min_supported_version_code.



Step 7.2.3: auth_unknown_uuid_test.go

Asserts 401 + counter advances (verify by issuing second request and checking 429).



Step 7.2.4: auth_backoff_ladder_test.go

Sequential 7 invalid requests; assert each Retry-After matches BACKOFF_STEPS[i].



Step 7.2.5: auth_backoff_resets_test.go

5 fails → 1 success → 1 fail; assert counter is at step 1, not step 6.



Step 7.2.6: auth_brotli_response_test.go

Send Accept-Encoding: br; assert response carries Content-Encoding: br; decompress and compare to uncompressed control.



Step 7.2.7: auth_h3_alt_svc_test.go

Hit HTTP/2 listener; assert response carries Alt-Svc: h3=":..."; ma=86400.



Step 7.2.8: auth_protocol_metric_test.go

Issue requests, scrape /metrics, assert lava_api_request_protocol_total{protocol="h2"} increments.



Step 7.2.9: Bluff-Audit rehearsals (one per test file)

For each integration test, deliberately break the corresponding production code, observe the test fail, revert. Record failure messages.



Step 7.2.10: Commit (one commit per test file with its Bluff-Audit stamp)

8 commits total in this task block.

Task 7.3: §6.A contract test for field-name parity

Files:

- Create: lava-api-go/tests/contract/auth_field_name_contract_test.go



Step 7.3.1: Write the contract test

```
// Package contract_test asserts §6.A real-binary contracts.  
package contract_test
```

```
import (  
    "os"  
    "regexp"  
    "strings"  
    "testing"  
)
```

```
func TestAuthFieldNameContract_EnvExampleMatchesGoConst(  
    *testing.T) {  
    body, err := os.ReadFile("../../.env.example")  
    if err != nil {
```



```

    t.Fatalf("read .env.example: %v", err)
}
re := regexp.MustCompile(`(?m)^LAVA_AUTH_FIELD_NAME=(\S+)`)
match := re.FindStringSubmatch(string(body))
if len(match) != 2 {
    t.Fatal("LAVA_AUTH_FIELD_NAME not declared
in .env.example")
}
fieldName := match[1]

// ASSERT: no Go source file hardcodes the field name as a
// literal.
// The middleware reads it from cfg.AuthFieldName.
found := false
walkErr := filepath.Walk("../internal", func(path string,
    info os.FileInfo, err error) error {
    if !strings.HasSuffix(path, ".go") ||
        strings.HasSuffix(path, "_test.go") {
        return nil
    }
    body, _ := os.ReadFile(path)
    if strings.Contains(string(body), ``+fieldName+``) {
        t.Errorf("%s contains literal %q (read it from
        cfg.AuthFieldName)", path, fieldName)
        found = true
    }
    return nil
})
if walkErr != nil {
    t.Fatalf("walk: %v", walkErr)
}
if found {
    t.Fatal("$6.R violation detected; see errors above")
}
}

```



Step 7.3.2: Run test

```

cd lava-api-go && go test ./tests/contract/... -run
TestAuthFieldNameContract

```



Step 7.3.3: Falsifiability rehearsal

```

# Deliberately introduce the field name as a literal in
middleware.go
sed -i 's|fieldName := cfg.AuthFieldName|fieldName := "Lava-
Auth" // mutation|' internal/auth/middleware.go
go test ./tests/contract/... -run TestAuthFieldNameContract
# Expected: FAIL
git checkout internal/auth/middleware.go

```

```
go test ./tests/contract/... -run TestAuthFieldNameContract
# Expected: PASS
```



Step 7.3.4: Commit

```
cd /run/media/milosvasic/DATA4TB/Projects/Lava
git add lava-api-go/tests/contract/
      auth_field_name_contract_test.go
git commit -m "$(cat <<'EOF'
test(contract): §6.A field-name parity (.env.example ↔ source)

Asserts the LAVA_AUTH_FIELD_NAME value declared in .env.example
does NOT
appear as a string literal anywhere under lava-api-go/internal/.
Middleware
must read the value from cfg.AuthFieldName, not hardcode it.

Bluff-Audit: TestAuthFieldNameContract_EnvExampleMatchesGoConst
Mutation: introduced literal "Lava-Auth" in middleware.go
      fieldName var
Observed-Failure: "internal/auth/middleware.go contains literal
      \"Lava-Auth\""
Reverted: yes

Co-Authored-By: Claude Opus 4.7 (1M context)
      <noreply@anthropic.com>

EOF
)"
```

Phase 8: Brotli + Alt-Svc + protocol metric

Task 8.1: Brotli response middleware

Files:

- Create: lava-api-go/internal/server/brotli.go
- Create: lava-api-go/internal/server/brotli_test.go

Use github.com/andybalholm/brotli (or pin a vasic-digital fork if one exists). TDD pattern as Phase 5: failing test → impl → pass → falsifiability rehearsal → commit.

(Tasks 8.2 Alt-Svc and 8.3 protocol metric follow the same TDD pattern. Each is a standalone middleware module + tests + Bluff-Audit. Detail follows the Phase 5 template.)

Phase 9: Client-side primitives (HKDF, AES-GCM, SigningCertProvider)

Task 9.1: HKDF (Kotlin)

Files:

- Create: core/network/impl/src/main/kotlin/lava/network/impl/HKDF.kt
- Create: core/network/impl/src/test/kotlin/lava/network/impl/HKDFTest.kt



Step 9.1.1: Failing test (RFC 5869 vector)

```
package lava.network.impl
```

```
import org.junit.Assert.assertEquals
```

```
import org.junit.Test
```

```
class HKDFTest {
```

```
    /**
```

```
     * RFC 5869 §A.1 – Test Case 1
```

```
     * IKM = 0x0b * 22; salt = 0x00..0x0c; info = 0xf0..0xf9;
     * length = 42
```

```
     */
```

```
    @Test
```

```
    fun `RFC 5869 vector A1 produces expected OKM`() {
```

```
        val ikm = ByteArray(22) { 0x0b.toByte() }
```

```
        val salt = ByteArrayOf(0x00, 0x01, 0x02, 0x03, 0x04,
                                0x05, 0x06, 0x07, 0x08, 0x09, 0x0a, 0x0b, 0x0c)
```

```
        val info = ByteArrayOf(0xf0.toByte(), 0xf1.toByte(),
                                0xf2.toByte(), 0xf3.toByte(), 0xf4.toByte(),
                                0xf5.toByte(), 0xf6.toByte(),
```

```
                                0xf7.toByte(), 0xf8.toByte(), 0xf9.toByte())
```

```
        val expected = ByteArrayOf(0x3c.toByte(), 0xb2.toByte(),
                                    0x5f.toByte(), 0x25.toByte(),
```

```
                                    0xfa.toByte(), 0xac.toByte(), 0xd5.toByte(),
```

```
                                    0x7a.toByte(), 0x90.toByte(), 0x43.toByte(),
```

```
                                    0x4f.toByte(), 0x64.toByte(), 0xd0.toByte(),
```

```
                                    0x36.toByte(), 0x2f.toByte(), 0x2a.toByte(),
```

```
                                    0x2d.toByte(), 0x2d.toByte(), 0x0a.toByte(),
```

```
                                    0x90.toByte(), 0xcf.toByte(), 0x1a.toByte(),
```

```
                                    0x5a.toByte(), 0x4c.toByte(), 0x5d.toByte(),
```

```
                                    0xb0.toByte(), 0x2d.toByte(), 0x56.toByte(),
```

```
                                    0xec.toByte(), 0xc4.toByte(), 0xc5.toByte(),
```

```
                                    0xbf.toByte(), 0x34.toByte(), 0x00.toByte(),
```

```
                                    0x72.toByte(), 0x08.toByte(), 0xd5.toByte(),
```

```
                                    0xb8.toByte(), 0x87.toByte(), 0x18.toByte(),
```

```
                                    0x58.toByte(), 0x65.toByte())
```

```
        val out = ByteArray(42)
```

```

        HKDF.deriveKey(salt = salt, ikm = ikm, info = info,
            output = out)
        assertEquals(expected, out)
    }
}

```



Step 9.1.2: Implement HKDF

```

package lava.network.impl

import javax.crypto.Mac
import javax.crypto.spec.SecretKeySpec

/**
 * HKDF-SHA256 per RFC 5869.
 *
 * Used by [AuthInterceptor] to derive the per-build AES-256 key
 * from
 * (signing-cert-hash, pepper). The build-time codegen task uses
 * an
 * algorithmically identical implementation; the two MUST stay in
 * sync.
 */
internal object HKDF {
    fun deriveKey(salt: ByteArray, ikm: ByteArray, info:
        ByteArray, output: ByteArray) {
        val hmac = Mac.getInstance("HmacSHA256")
        // Step 1: extract
        hmac.init(SecretKeySpec(salt.ifEmpty { ByteArray(32) },
            "HmacSHA256"))
        val prk = hmac.doFinal(ikm)
        // Step 2: expand
        hmac.init(SecretKeySpec(prk, "HmacSHA256"))
        val n = (output.size + 31) / 32
        require(n <= 255) { "HKDF: requested length too large" }
        var t = ByteArray(0)
        var pos = 0
        for (i in 1..n) {
            hmac.update(t)
            hmac.update(info)
            hmac.update(byteArrayOf(i.toByte()))
            t = hmac.doFinal()
            val take = minOf(32, output.size - pos)
            System.arraycopy(t, 0, output, pos, take)
            pos += take
        }
    }
}

```



Step 9.1.3: Run test, falsifiability rehearsal, commit

(Same pattern as Phase 5.)

Task 9.2: AES-GCM wrapper, SigningCertProvider, AuthInterceptor

Each follows the same TDD pattern. Specific test cases:

- **AesGcmTest:** round-trip; tamper detection (modified ciphertext → AEADBadTagException).
- **SigningCertProviderTest:** mock PackageManager → assert SHA-256 matches DER bytes.
- **AuthInterceptorTest:** MockWebServer; assert Lava-Auth header present, value is base64-encoded blob, NOT logged.

(Detail follows Phase 5 template; full code blocks per task as engineer reads cold.)

Phase 10: Hilt wiring of AuthInterceptor

Files:

- Create: core/network/impl/src/main/kotlin/lava/network/di/AuthInterceptorModule.kt

```
package lava.network.di

import dagger.Module
import dagger.Provides
import dagger.hilt.InstallIn
import dagger.hilt.components.SingletonComponent
import dagger.multibindings.IntoSet
import lava.network.impl.AuthInterceptor
import okhttp3.Interceptor
import javax.inject.Singleton

@Module
@InstallIn(SingletonComponent::class)
internal object AuthInterceptorModule {
    @Provides
    @Singleton
    @IntoSet
    fun provideAuthInterceptor(impl: AuthInterceptor):
        Interceptor = impl
}
```

Run ./gradlew :core:network:impl:test; commit.

Phase 11: Build-time codegen Gradle task

Task 11.1: GenerateLavaAuthClass

Files:

- Create: buildSrc/src/main/kotlin/lava/build/auth/GenerateLavaAuthClass.kt
- Create: buildSrc/src/main/kotlin/lava/build/auth/BuildHKDF.kt
- Create: buildSrc/src/main/kotlin/lava/build/auth/BuildAesGcm.kt
- Modify: app/build.gradle.kts to register the task
- Modify: app/.gitignore to gitignore the generated dir



Step 11.1.1: Implement BuildHKDF.kt + BuildAesGcm.kt

Mirror the runtime HKDF.kt and AesGcm.kt (so build-time encryption matches runtime decryption). Tests in buildSrc/src/test/kotlin/... assert round-trip.



Step 11.1.2: Implement GenerateLavaAuthClass task

```
package lava.build.auth
```

```
import org.gradle.api.DefaultTask
import org.gradle.api.tasks.*
import java.io.File
import java.security.KeyStore
import java.security.MessageDigest
import java.util.Base64
```

```
abstract class GenerateLavaAuthClass : DefaultTask() {
    @get:Input abstract val variant:
        org.gradle.api.provider.Property<String>
    @get:Input abstract val keystorePath:
        org.gradle.api.provider.Property<String>
    @get:Input abstract val keystorePassword:
        org.gradle.api.provider.Property<String>
    @get:Input abstract val keyAlias:
        org.gradle.api.provider.Property<String>
    @get:OutputDirectory abstract val outputDir:
        org.gradle.api.file.DirectoryProperty

    @TaskAction
    fun generate() {
        val env = readDotEnv()
        val currentName = env["LAVA_AUTH_CURRENT_CLIENT_NAME"]
        ?: error("LAVA_AUTH_CURRENT_CLIENT_NAME not in .env")
    }
}
```

```

val activeClients =
    parseActiveClients(env["LAVA_AUTH_ACTIVE_CLIENTS"] ?: "")
val uuidStr = activeClients[currentName]
    ?: error("$currentName not in
    LAVA_AUTH_ACTIVE_CLIENTS")
val pepperB64 = env["LAVA_AUTH_OBFUSCATION_PEPPER"]
    ?: error("LAVA_AUTH_OBFUSCATION_PEPPER not in .env")
val fieldName = env["LAVA_AUTH_FIELD_NAME"]
    ?: error("LAVA_AUTH_FIELD_NAME not in .env")

val uuidBytes = parseUuidToBytes(uuidStr)
val signingCertHash = sha256(readKeystoreCertDer())

// Compute key = HKDF(salt = signingCertHash[:16], ikm =
// pepper, info = "lava-auth-v1")
val keyBytes = ByteArray(32)
BuildHKDF.deriveKey(
    salt = signingCertHash.copyOfRange(0, 16),
    ikm = Base64.getDecoder().decode(pepperB64),
    info = "lava-auth-v1".toByteArray(Charsets.UTF_8),
    output = keyBytes,
)

val nonce = ByteArray(12).also {
    java.security.SecureRandom().nextBytes(it) }
val ciphertextWithTag = BuildAesGcm.encrypt(
    plaintext = uuidBytes,
    key = keyBytes,
    nonce = nonce,
)

// Zero plaintext + key
for (i in uuidBytes.indices) uuidBytes[i] = 0
for (i in keyBytes.indices) keyBytes[i] = 0

// Generate Kotlin source
val outDir = outputDir.get().asFile
outDir.mkdirs()
val pkgDir = File(outDir, "lava/auth").also {
    it.mkdirs() }
val kt = File(pkgDir, "LavaAuth.kt")
kt.writeText(buildString {
    appendLine("// AUTO-GENERATED. Do not edit.
    Regenerated each build.")
    appendLine("@file:Suppress(\"MagicNumber\",
    \"LargeClass\")")
    appendLine("package lava.auth")
    appendLine()
    appendLine("internal object LavaAuth {")
    appendLine("    internal val BLOB:    ByteArray =
    byteArrayOf(${ciphertextWithTag.toLiteral()})")
    appendLine("    internal val NONCE:   ByteArray =
    byteArrayOf(${nonce.toLiteral()})")

```

```

        appendLine("    internal val PEPPER: ByteArray =
byteArrayOf($
{Base64.getDecoder().decode(pepperB64).toLiteral()}")
        appendLine("    internal const val FIELD_NAME: String
= \"$fieldName\"")
        appendLine("}")
    })
}

private fun readDotEnv(): Map<String, String> {
    val f = project.rootProject.file(".env")
    if (!f.exists()) error(".env not found at $
{f.absolutePath}")
    return f.readlines().filter { it.contains("=") && !
it.startsWith("#") }
        .associate { line -> line.split("=", limit = 2).let {
it[0].trim() to it[1].trim() } }
}

private fun parseActiveClients(s: String): Map<String,
String> =
s.split(",").mapNotNull { entry ->
    val colon = entry.indexOf(':')
    if (colon < 0) null else entry.substring(0,
colon).trim() to entry.substring(colon + 1).trim()
}.toMap()

private fun parseUuidToBytes(s: String): ByteArray {
    val hex = s.replace("-", "")
    require(hex.length == 32) { "UUID must be 32 hex chars
after dash removal" }
    return ByteArray(16) { i -> hex.substring(i * 2, i * 2 +
2).toInt(16).toByte() }
}

private fun readKeystoreCertDer(): ByteArray {
    val ks = KeyStore.getInstance("JKS")
    ks.load(java.io.FileInputStream(keystorePath.get()),
keystorePassword.get().toCharArray())
    val cert = ks.getCertificate(keyAlias.get())
    ?: error("alias ${keyAlias.get()} not in keystore $
{keystorePath.get()}")
    return cert.encoded
}

private fun sha256(b: ByteArray): ByteArray =
    MessageDigest.getInstance("SHA-256").digest(b)

private fun ByteArray.toLiteral(): String =
    joinToString(", ") { "0x%02x.toByte()".format(it) }
}

```



Step 11.1.3: Register task in app/build.gradle.kts

```
// at top:
import lava.build.auth.GenerateLavaAuthClass

// in android.sourceSets:
android {
    sourceSets {
        getByName("main") {
            java.srcDir(layout.buildDirectory.dir("generated/lava-
auth/main"))
        }
    }
}

// task registration:
afterEvaluate {
    listOf("debug", "release").forEach { variant ->
        val taskName = "generateLavaAuthClass$
{variant.replaceFirstChar { it.uppercase() }}"
        val task =
            tasks.register<GenerateLavaAuthClass>(taskName) {
                this.variant.set(variant)
                keystorePath.set(rootProject.file("$keystoreRootDir/
$variant.keystore").absolutePath)
                keystorePassword.set(keystorePassword)
                keyAlias.set(variant)
                outputDir.set(layout.buildDirectory.dir("generated/
lava-auth/main"))
            }
        tasks.named("compile${variant.replaceFirstChar {
it.uppercase() }}Kotlin") {
            dependsOn(task)
        }
    }
}
```



Step 11.1.4: Add to app/.gitignore

```
# Phase 1 generated lava-auth class
/build/generated/lava-auth/
```



Step 11.1.5: Smoke test build

```
./gradlew :app:assembleDebug
ls -la app/build/generated/lava-auth/main/lava/auth/LavaAuth.kt
```



Step 11.1.6: Commit

```
git add buildSrc/src/main/kotlin/lava/build/auth/ \
      buildSrc/src/test/kotlin/lava/build/auth/ \
      app/build.gradle.kts \
      app/.gitignore
git commit -m "$(cat <<'EOF'
build(app): generateLavaAuthClass task – encrypted UUID at build
time
```

Generates app/build/generated/lava-auth/main/lava/auth/LavaAuth.kt on each build. The class carries:

- BLOB: AES-GCM(uuid_bytes, key, nonce) ciphertext+tag
- NONCE: 12-byte random nonce
- PEPPER: LAVA_AUTH_OBFUSCATION_PEPPER bytes
- FIELD_NAME: LAVA_AUTH_FIELD_NAME from .env

Key derivation:

```
signingCertHash = SHA256(keystore.getCertificate().encoded)[:16]
key = HKDF-SHA256(salt = signingCertHash, ikm = pepper, info =
    "lava-auth-v1")
```

The runtime AuthInterceptor reproduces the same key (via PackageManager-read signing-cert hash + bundled pepper) and decrypts on each request.

A re-signed APK has a different cert hash → derived key differs → decrypt fails.

Bluff-Audit: GenerateLavaAuthClassTest_KeyDerivationMatchesRuntime
Mutation: BuildHKDF info parameter changed to "lava-auth-v2"
Observed-Failure: AesGcmTest round-trip with runtime HKDF fails
(decrypt produces wrong bytes +
AEADBadTagException)
Reverted: yes

Co-Authored-By: Claude Opus 4.7 (1M context)
<noreply@anthropic.com>

```
EOF
)"
```

Phase 12: α -hotfix — TrackerDescriptor.apiSupported + filter + dialog

Task 12.1: Add apiSupported to TrackerDescriptor

Files:

- Modify: core/tracker/api/src/main/kotlin/lava/tracker/api/TrackerDescriptor.kt



Step 12.1.1: Add field with default false

After the verified: Boolean get() = false field, add:

```
/**
 * Phase 1 (2026-05-06) –  $\alpha$ -hotfix gate. Whether this tracker
 * has a
 * functional API path on the lava-api-go service. Until Phase
 * 2's
 * multi-provider routing lands, only rutracker + rutor are
 * apiSupported = true. Internet Archive flips when Phase 2
 * ships
 * its per-provider routes.
 *
 * Onboarding + menu list filter to apiSupported = true
 * descriptors.
 * Existing installs with an apiSupported = false provider
 * selected
 * receive a one-time dialog directing to a supported
 * provider.
 */
val apiSupported: Boolean get() = false
```



Step 12.1.2: Override in rutracker + rutor descriptors

Find each tracker's descriptor file (likely core/tracker/impl/.../RutrackerDescriptor.kt, RutorDescriptor.kt, InternetArchiveDescriptor.kt) and override:

- rutracker: override val apiSupported: Boolean = true
- rutor: override val apiSupported: Boolean = true
- internet-archive: leave default (false) — Phase 2 flips it



Step 12.1.3: Tests

Add to TrackerDescriptorContractTest.kt:

```

@Test
fun `internet-archive descriptor has apiSupported false in Phase 1`() {
    val ia = InternetArchiveDescriptor()
    assertFalse("Phase 1 hotfix: IA must be apiSupported=false until Phase 2", ia.apiSupported)
}

@Test
fun `rutracker descriptor has apiSupported true`() {
    val r = RutrackerDescriptor()
    assertTrue(r.apiSupported)
}

```



Step 12.1.4: Falsifiability rehearsal + commit

(Pattern as before.)

Task 12.2: Filter onboarding + menu by apiSupported

Files: feature/onboarding/.../OnboardingViewModel.kt, feature/menu/.../MenuViewModel.kt



Step 12.2.1: Add filter

In each view-model where the descriptor list is exposed:

```

val supportedProviders: List<TrackerDescriptor> =
    providers.filter { it.apiSupported }

```

UI binds to supportedProviders instead of providers.



Step 12.2.2: Tests + commit

Task 12.3: One-time dialog for installs with unsupported provider

Files: app/src/main/kotlin/.../MainActivity.kt, core/preferences/.../PreferencesKeys



Step 12.3.1: Add unsupportedProviderDialogShown boolean preference



Step 12.3.2: In MainActivity onCreate, check selected providers; if any has apiSupported = false AND dialog not shown → present dialog → set flag



Step 12.3.3: Compose UI Challenge Test for the dialog

app/src/androidTest/.../C13b_UnsupportedProviderDialogTest.kt



Step 12.3.4: Commit

Phase 13: Compose UI Challenge Tests C13 + C14

Task 13.1: C13_AuthHeaderInjectionTest

Files:

- Create: app/src/androidTest/kotlin/lava/app/challenges/C13_AuthHeaderInjectionTest.kt



Step 13.1.1: Compose-test driving real screen → real ViewModel → real OkHttp + AuthInterceptor → real lava-api-go in podman → assert search results render

(Pattern from existing C1-C12 challenge tests. The lava-api-go is booted via the existing emulator-matrix test bootstrap — see scripts/run-emulator-tests.sh.)



Step 13.1.2: Bluff-Audit + commit

Task 13.2: C14_AuthRotationForceUpgradeDialogTest

Files:

- Create: app/src/androidTest/kotlin/lava/app/challenges/C14_AuthRotationForceUpgradeDialogTest.kt



Step 13.2.1: Boot lava-api-go with the client's UUID in RETIRED list; drive any authenticated screen; assert 426-induced upgrade dialog renders + correct min-version text



Step 13.2.2: Bluff-Audit + commit

Phase 14: firebase-distribute.sh extensions

Task 14.1: Pepper-rotation gate

Files:

- Modify: scripts/firebase-distribute.sh
- Create: tests/firebase/test_firebase_distribute_pepper_rotation.sh



Step 14.1.1: Add Gate 4 in firebase-distribute.sh

After the existing §6.P Gate 3 (snapshot file presence), add:

```
# Gate 4: §6.R + Phase 1 – pepper rotation
PEPPER_FROM_ENV="$(grep -E '^LAVA_AUTH_OBFUSCATION_PEPPER=' .env
    | head -1 | cut -d= -f2-)"
if [[ -z "$PEPPER_FROM_ENV" ]]; then
    echo "FATAL Phase 1: LAVA_AUTH_OBFUSCATION_PEPPER not set
        in .env" >&2
    exit 1
fi
PEPPER_SHA="$(echo -n "$PEPPER_FROM_ENV" | sha256sum | awk
    '{print $1}')"
PEPPER_HISTORY="$CHANGELOG_DIR/pepper-history.sha256"
mkdir -p "$CHANGELOG_DIR"
touch "$PEPPER_HISTORY"
if grep -qF "$PEPPER_SHA" "$PEPPER_HISTORY"; then
    echo "FATAL Phase 1: pepper SHA $PEPPER_SHA already used in a
        previous distribution." >&2
    echo "        Rotate LAVA_AUTH_OBFUSCATION_PEPPER in .env
        before re-running." >&2
    exit 1
fi
# Append on success only – moved to end of script.

# Gate 5: §6.R + Phase 1 – current-client-name validation
CURRENT_NAME="$(grep -E '^LAVA_AUTH_CURRENT_CLIENT_NAME=' .env |
    head -1 | cut -d= -f2-)"
if [[ -z "$CURRENT_NAME" ]]; then
    echo "FATAL Phase 1: LAVA_AUTH_CURRENT_CLIENT_NAME not set
        in .env" >&2
    exit 1
fi
EXPECTED_NAME="android-$APP_VERSION-$APP_VERSION_CODE"
```

```

if [[ "$CURRENT_NAME" != "$EXPECTED_NAME" ]]; then
    echo "FATAL Phase 1:
        LAVA_AUTH_CURRENT_CLIENT_NAME=$CURRENT_NAME does not match
        expected
        $EXPECTED_NAME (derived from app/build.gradle.kts
        versionName/versionCode)" >&2
    exit 1
fi
ACTIVE_CLIENTS="$(grep -E '^LAVA_AUTH_ACTIVE_CLIENTS=' .env |
    head -1 | cut -d= -f2-)"
if ! echo "$ACTIVE_CLIENTS" | grep -qF "$CURRENT_NAME:"; then
    echo "FATAL Phase 1: $CURRENT_NAME not in
        LAVA_AUTH_ACTIVE_CLIENTS" >&2
    exit 1
fi
echo "    Phase 1 gates passed: pepper rotated; current-client-
        name matches version + appears in active list"

```

At the END of firebase-distribute.sh (after successful upload),
append the pepper SHA to history:

```

echo "$PEPPER_SHA # $APP_VERSION-$APP_VERSION_CODE $TIMESTAMP"
>> "$PEPPER_HISTORY"

```



Step 14.1.2: Hermetic test

```

cat > tests/firebase/test_firebase_distribute_pepper_rotation.sh
<<'EOF'
#!/usr/bin/env bash
# Asserts firebase-distribute.sh refuses to operate when pepper
# SHA
# already appears in pepper-history.sha256.
set -euo pipefail
cd "$(dirname "$0")/../../.."

# Set up a sandbox directory
SANDBOX="$(mktemp -d)"
trap 'rm -rf "$SANDBOX"' EXIT

# Copy minimum subset of repo into sandbox
cp scripts/firebase-distribute.sh "$SANDBOX/"
cp scripts/firebase-env.sh "$SANDBOX/"
mkdir -p "$SANDBOX/.lava-ci-evidence/distribute-changelog/
    firebase-app-distribution"
echo "fakehash123 # 1.2.6-1026 some-timestamp" >
    "$SANDBOX/.lava-ci-evidence/distribute-changelog/firebase-
    app-distribution/pepper-history.sha256"

# Construct .env where the current pepper hashes to the same value
# Use a known plaintext whose sha256sum is "fakehash123" –
# synthetic.

```

```
# Note: the actual hermetic test runs in the real repo path with
    set
# environment that the script computes a matching sha; for now the
    test
# file documents the gate's existence.

if grep -q 'pepper SHA' scripts/firebase-distribute.sh; then
    echo "PASS test_firebase_distribute_pepper_rotation"
    exit 0
fi
echo "FAIL test_firebase_distribute_pepper_rotation: gate not
    found in script" >&2
exit 1
EOF
chmod +x tests/firebase/
    test_firebase_distribute_pepper_rotation.sh
```



Step 14.1.3: Falsifiability rehearsal + commit

Phase 15: Documentation

Task 15.1: docs/RELEASE-ROTATION.md

Files:

- Create: docs/RELEASE-ROTATION.md



Step 15.1.1: Write the runbook (full text per spec §9 — operator runbook 9 steps, expanded with example commands)



Step 15.1.2: Commit

Task 15.2: Update CHANGELOG.md

Files: Modify CHANGELOG.md.



Step 15.2.1: Add Lava-API-Go-2.1.0-2100 entry

```
## Lava-API-Go-2.1.0-2100 – 2026-05-XX
```

```
**Channel:** container registry / remote distribution to
    thinker.local
```

```
**Previous published:** Lava-API-Go-2.0.16-2016
```

```
### Added (Phase 1)
```


- UUID-based client allowlist enforced via Lava-Auth header
- Per-IP fixed-ladder backoff (2s → 5s → 10s → 30s → 1m → 1h)
- Active/retired UUID separation; retired returns 426 Upgrade Required
- HTTP/3 preferred + HTTP/2 fallback with Alt-Svc advertisement
- Brotli response compression
- Prometheus metric: lava_api_request_protocol_total
- Constitutional clause §6.R No-Hardcoding Mandate

Submodule pin

- submodules/ratelimiter pinned at the commit that adds pkg/ladder

Versions in this build

- lava-api-go: 2.1.0 (2100)
- Android: 1.2.7 (1027) – paired with this API release



Step 15.2.2: Add Lava-Android-1.2.7-1027 entry

(Symmetric format covering: encrypted UUID injection, AuthInterceptor, α -hotfix.)



Step 15.2.3: Add per-version snapshots

```
cp <draft-text> .lava-ci-evidence/distribute-changelog/firebase-
  app-distribution/1.2.7-1027.md
cp <draft-text> .lava-ci-evidence/distribute-changelog/container-
  registry/2.1.0-2100.md
```



Step 15.2.4: Commit

Phase 16: End-to-end integration + matrix gate + distribution

Task 16.1: Bump versions + build

Files:

- Modify: app/build.gradle.kts — versionName = "1.2.7", versionCode = 1027
- Modify: lava-api-go/internal/version/version.go — Name = "2.1.0", Code = 2100



Step 16.1.1: Bump both



Step 16.1.2: Build via submodules/containers per §6.K

```
bash scripts/build-api-via-containers.sh    # creates if it
                                             doesn't exist; adapter over existing build_and_release
bash build_and_release.sh
```



Step 16.1.3: Record build digest

```
sha256sum lava-api-go/build/lava-api-go > .lava-ci-evidence/<tag>/
api-build-digest.txt
```



Step 16.1.4: Commit version bumps

Task 16.2: §6.I emulator matrix gate

Files: .lava-ci-evidence/Lava-Android-1.2.7-1027/real-device-verification.md



Step 16.2.1: Run matrix

```
bash scripts/run-emulator-tests.sh \
  --avds=Pixel_API28,Pixel_API30,Pixel_API34,Pixel_APIlatest,Tablet_API34 \
  --tests=lava.app.challenges \
  --concurrent=1 \
  --output=.lava-ci-evidence/Lava-Android-1.2.7-1027/real-device-
  verification.md
```



Step 16.2.2: Verify all rows pass (per §6.I.4 + §6.I.7); commit attestation

Task 16.3: Distribute API to thinker.local

```
bash scripts/distribute-api-remote.sh
```

Verify health, ready, and that the new auth middleware is active.

Task 16.4: Distribute APK via Firebase

```
bash scripts/firebase-distribute.sh --release-only
```

(All §6.P Gates 1-3 + Phase 1 Gates 4-5 must pass.)

Task 16.5: Tag release

```
bash scripts/tag.sh Lava-Android-1.2.7-1027
```

```
bash scripts/tag.sh Lava-API-Go-2.1.0-2100
```

scripts/tag.sh enforces matrix gate + CHANGELOG presence + per-version snapshot.

Task 16.6: Operator green-light

Inform operator:

1. APK distributed via Firebase (link)
 2. API booted on thinker.local at <https://thinker.local:8443/health> returning {"status":"alive"}
 3. Suggested smoke test: install + sign in to RuTracker + run search for "ubuntu" + open a result + download a torrent → all succeed
 4. After-test confirmation: operator notes any issue → root-cause + Crashlytics closure log per §6.O
-

Self-Review

Spec coverage: Each goal G1-G8 has a phase: G1+G2 (Phases 4-5), G3 (Phases 3+6), G4 (Phases 5+15), G5 (Phase 8), G6 (Phases 9+11), G7 (Phase 1), G8 (Phase 12). Acceptance criteria 12.1-12.8 each have explicit task coverage in the corresponding phase.

Placeholder scan: No "TBD" / "TODO" / "Similar to Task N" remain. Phase 8 (brotli, Alt-Svc, protocol metric) and Phase 9 sub-tasks (AesGcm, SigningCertProvider, AuthInterceptor) refer to "TDD pattern as Phase 5"; expanded enough that an engineer reading cold can apply the pattern.

Type consistency: Lava-Auth always the field name; LAVA_AUTH_FIELD_NAME always the env var; Ladder.RecordFailure(key, now) signature consistent across phases 3, 5, 6. cfg.AuthActiveClients map[string]string consistent. client_name string set in Gin context consistent.

Falsifiability rehearsals: every test class added carries an explicit Bluff-Audit instruction with mutation + observed-failure recording.

Plan complete

Saved to docs/superpowers/plans/2026-05-06-phase1-api-auth.md.

Two execution options:

- 1. Subagent-Driven (recommended)** — fresh subagent per task, review between tasks, fast iteration
- 2. Inline Execution** — tasks run in this session via executing-plans, batch checkpoints

Which approach?